

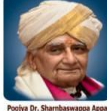
Centenary Celebrated Sharnbasveshwar Vidya Vardhaka Sangha's



Poojya Matoshree Dr. Dobbajayi S. Appa
President, Sharnbasveshwar Vidya Vardhaka Sangha
Chancellor, Sharnbasveshwar University, Kalaburagi



Poojya Chikajjenni Doddappa Appa
V. Mahadeviah Postgraduate, Sharnbasveshwar Samithi



Poojya Dr. Sharnbaswappa Appa
V. Mahadeviah Postgraduate, Sharnbasveshwar Samithi
Former President, Sharnbasveshwar Vidya Vardhaka Sangha
Founder Chancellor, Sharnbasveshwar University, Kalaburagi

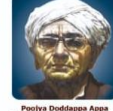
ಶರಣಬಸವ
Sharnbasva

ಕಲಬುರಗಿ-585 103
ಕರ್ನಾಟಕ-ಭಾರತ
ಸ್ಥಾಪನೆ : 2017



ವಿಶ್ವವಿದ್ಯಾಲಯ
University

Kalaburagi-585 103
Karnataka-India
Estd.: 2017



Poojya Doddappa Appa
7th Mahadeviah Postgraduate, Sharnbasveshwar Samithi
Founder President, Sharnbasveshwar Vidya Vardhaka Sangha



Matoshree Godutal
Doddappa Appa

Faculty of Engineering Technology (Co-Ed)

Department of Artificial Intelligence and Data Science

Lab Manual

Cyber Security and Digital Forensics Lab (22CSL77)

List of Contents

Sl.No	Programs
1	Perform OSINT and footprinting on a target domain (whois, DNS, Google dorks) and produce an asset list.
2	Scan lab hosts for open ports/services (Nmap) and produce a vulnerability-priority sheet with remediation suggestions
3	Demonstration of password vulnerability Tools: Hashcat, John the Ripper
4	Master the Fundamentals of Digital Forensics and Evidence Collection using Autopsy.
5	Exploit SQL injection in an intentionally vulnerable web app (DVWA/OWASP Juice Shop) and document PoC and fixes.
6	Capture network traffic (Wireshark) for given scenarios, identify suspicious flows, and suggest detection rules
7	Embed/extract hidden data in files (image/audio/doc) and evaluate detectability and
8	Analyze a provided memory dump using Volatility to identify processes, network connections, and possible malicious artifacts
9	Create a forensic image (FTK Imager/dd), verify integrity (hashes), and recover deleted files via carving.
10	Apply the IR lifecycle to a simulated incident (ransomware or data exfiltration), produce timeline, containment steps and incident report.

1.Perform OSINT and Footprinting on a target domain (whois, DNS , Google dorks) and produce an asset list.

OSINT: gathering publicly available information about a target from open sources to understand what it exposes without interacting with it.

Footprinting: mapping the target's technical surface by collecting details like domain data, DNS setup, network ranges, and visible services to define what exists before doing deeper analysis.

WHOIS

Steps:

1. **Access WHOIS Tool**
Open any WHOIS lookup website.
2. **Input Domain**
Enter the target domain name into the search box.(Here used suk.edu.in)
3. **Collect Domain Details**
Note creation date, expiry date, last update, and status.
4. **Record Name Servers**
Identify which DNS servers the domain uses.
5. **Identify Registrar**
Check which organization manages the domain registration.
6. **Check Registrant Info**
Capture the listed organization and location (if not redacted).
7. **Verify Raw WHOIS**
Scroll to the raw output to confirm all fields directly from the registry.

The screenshot displays a WHOIS lookup for the domain **suk.edu.in**. The interface is divided into several sections:

- Domain Information:** Lists key dates and status for suk.edu.in.

Field	Value
Domain	suk.edu.in
Registered On	2025-03-20
Expires On	2025-03-20
Updated On	2025-03-20
Status	ok
Name Servers	melny.ns.cloudflare.com seml.ns.cloudflare.com
- Registrar Information:** Provides details about the domain's registrar.

Field	Value
Registrar	ERENET India
IANA ID	800068
URL	http://www.ernet.in
Abuse Email	regal@ernet.net.in
Abuse Phone	+91 112359248
- Registrant Contact:** Shows the organization and location associated with the domain.

Field	Value
Organization	Sharnbasva University
State	Karnataka
Country	IN
- Raw Whois Data:** Displays the unformatted text output from the registry, including domain name, registrar, and contact details.

Additional elements visible include a sidebar with domain suggestions (e.g., sukfamily.com, sukphotography.com) and a 'On Sale' banner for 'iCU' domains.

DNS

Steps:

1. Open DNS checker in chrome
Under DNS lookup , enter your target domain (Here suk.edu.in)
2. Select record type
Choose “ALL” to display every available DNS record.
3. View results
Read each record category to understand how the domain is configured.

Some of the main records are:

• A Record

Maps the domain to an IPv4 address; shows the server hosting the site.

• AAAA Record

IPv6 equivalent of A record; absent here, meaning no IPv6 address configured.

• CNAME Record

Provides alias mapping; none found, so no subdomains pointing to another name.

• MX Record

Defines mail servers for the domain; used for email delivery routing.

• NS Record

Lists authoritative name servers; indicates DNS is managed by Cloudflare.

The screenshot shows a web-based DNS lookup tool. The left sidebar contains a search bar with 'suk.edu.in' entered, a 'DNS Server' dropdown set to 'Google', and a 'Record Type' selector set to 'ALL'. Below this are links for 'Lookup DNS', 'Reverse Tools', and 'DNS Lookup'. The main content area displays the 'Result for SUK.EDU.IN' with a table of records. The records are categorized by type: A, AAAA, CNAME, MX, NS, PTR, and SRV. The A record shows the IP address 103.248.152.254. The MX record shows the mail server mx.suk.edu.in. The NS record shows the authoritative name servers ns1.suk.edu.in and ns2.suk.edu.in.

Type	Domain Name	TTL	Address
A	suk.edu.in	300	103.248.152.254
AAAA			Sorry no record found!
CNAME			Sorry no record found!
MX	suk.edu.in	300	mx.suk.edu.in
NS	suk.edu.in	21600	ns1.suk.edu.in, ns2.suk.edu.in
PTR			Sorry no record found!
SRV			Sorry no record found!

Google Dorks

Google dorks: focused search operators that extract specific publicly indexed information using precise filters rather than broad queries.

Filter	Example	Description
site	site:starbucks.com	Only displays results related to "starbucks.com"
-site	-site:one.starbucks.com	"one.starbucks.com" will not appear in search results
inurl	inurl:mocha	Only webpages with the word "mocha" in its URL will appear
intitle	intitle:coffee	Only displays results which have "coffee" in its title
intext	intext:coffee	Only displays results with "coffee" in the body of the website
filetype	filetype:pdf	Only returns PDF documents

The screenshot shows a Google search interface with the query 'intitle:coffee'. The search results are filtered by 'All' and show various coffee products. A knowledge panel on the right provides information about coffee, including its definition and source (Wikipedia).

Google search results for 'intitle:coffee'.

Search filters: Price, Whole Bean, Nearby, Brand, NESCAFÉ, Starbucks, Images, Instant, Online, Recipe, Espresso Machines, Buy.

Results for Kalaburagi, Karnataka. Choose area.

Popular products:

- Nescafe Classic Coffee, ₹211, Free delivery by...
- Davidoff Coffee Rich Aroma 100g, ₹593, Free delivery by...
- Nescafe Intenso Whole Roasted Coff..., ₹1,250, Free delivery
- Tata Coffee Gold Instant Coffee, ₹348, Free 10 min deli...
- Bru Gold Instant Coffee, ₹234 ₹275, Free 10 min deli...

Under ₹250:

- Nescafe
- Davidoff Coffee
- ORBUU
- DAVIDOFF
- DAVIDOFF

Coffee
Beverage

Coffee is a beverage brewed from roasted, ground coffee beans. Darkly colored, bitter, and slightly acidic, coffee has a stimulating effect on humans, primarily due to its caffeine content, but decaffeinated coffee is also commercially available. There are also various coffee substitutes.

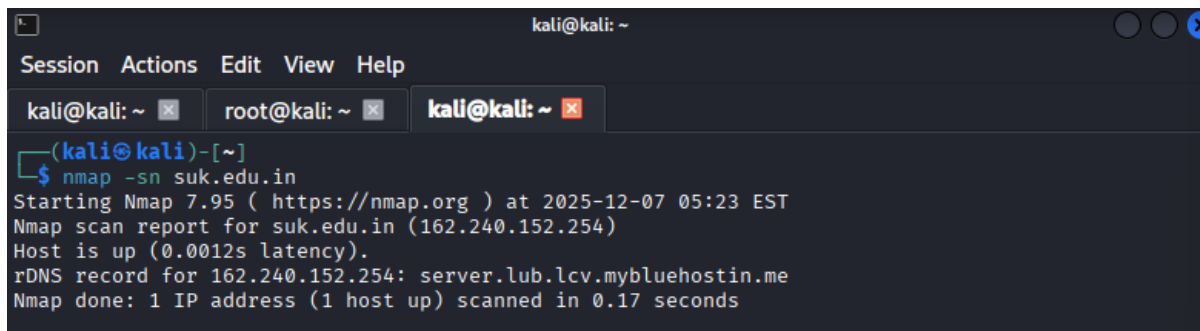
Source: Wikipedia

2. Scan the lab hosts for open ports/services (Nmap) and produce a vulnerability- priority sheet with remediation suggestions.

In kali terminal execute the below commands. (target can be any ip address or domain name)

- **nmap -sn <target>**

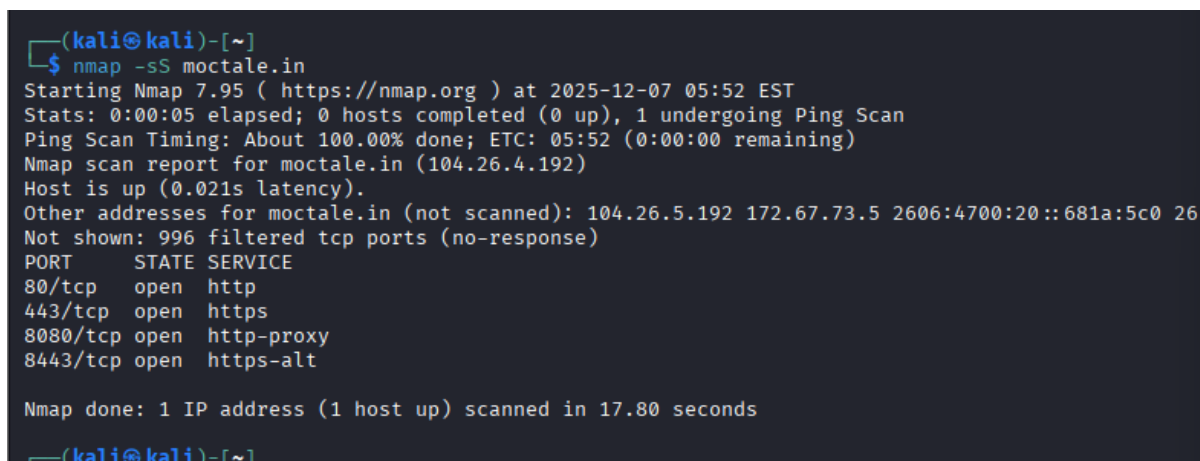
Host-discovery only; identifies which hosts are alive without scanning ports.



```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ x root@kali: ~ x kali@kali: ~ x  
(kali@kali)-[~]  
$ nmap -sn suk.edu.in  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:23 EST  
Nmap scan report for suk.edu.in (162.240.152.254)  
Host is up (0.0012s latency).  
rDNS record for 162.240.152.254: server.lub.lcv.mybluehostin.me  
Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

- **nmap -sS <target>**

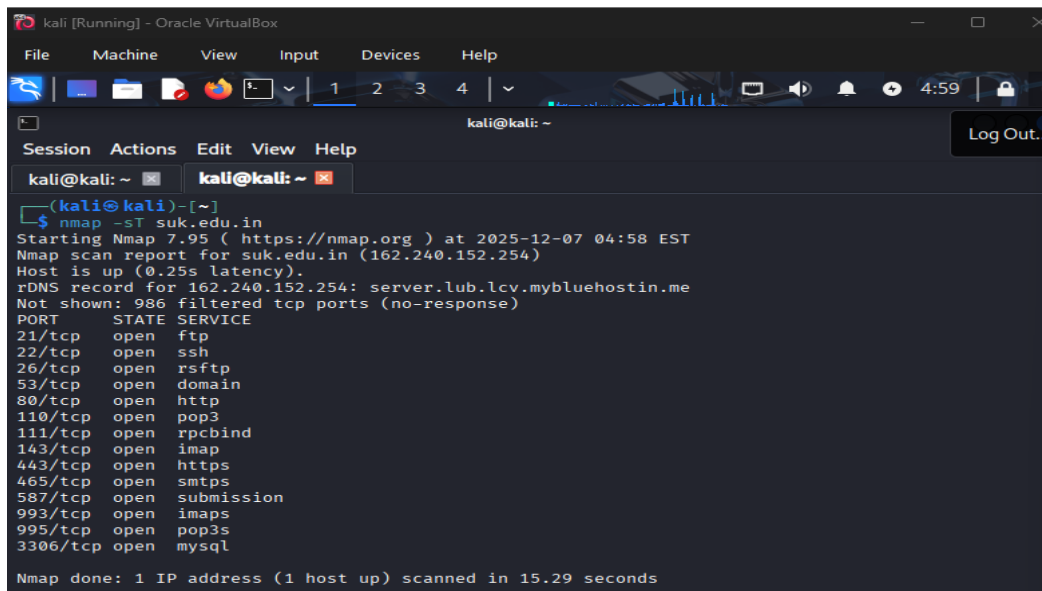
SYN scan; probes common TCP ports using half-open packets.



```
(kali@kali)-[~]  
$ nmap -sS moctale.in  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:52 EST  
Stats: 0:00:05 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan  
Ping Scan Timing: About 100.00% done; ETC: 05:52 (0:00:00 remaining)  
Nmap scan report for moctale.in (104.26.4.192)  
Host is up (0.021s latency).  
Other addresses for moctale.in (not scanned): 104.26.5.192 172.67.73.5 2606:4700:20::681a:5c0 26  
Not shown: 996 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
443/tcp   open  https  
8080/tcp  open  http-proxy  
8443/tcp  open  https-alt  
  
Nmap done: 1 IP address (1 host up) scanned in 17.80 seconds  
(kali@kali)-[~]
```

- **nmap -sT <target>**

TCP connect scan; completes full TCP handshakes when SYN scan is not allowed.

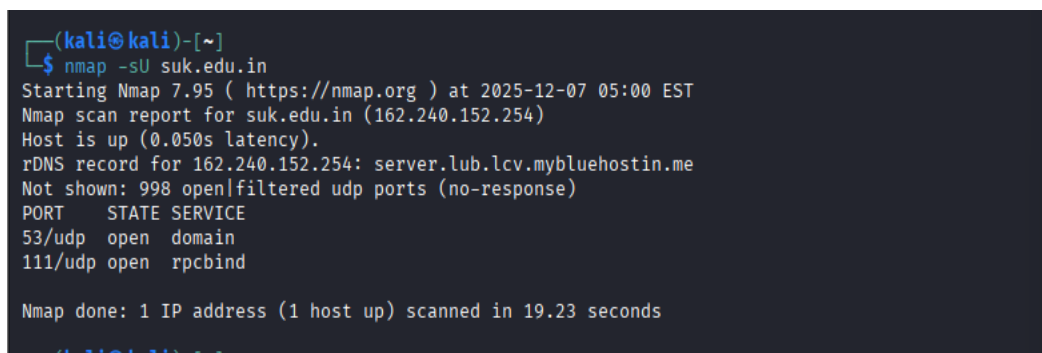


```
kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
(kali@kali)-[~]
$ nmap -sT suk.edu.in
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 04:58 EST
Nmap scan report for suk.edu.in (162.240.152.254)
Host is up (0.25s latency).
rDNS record for 162.240.152.254: server.lub.lcv.mybluehostin.me
Not shown: 986 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
26/tcp    open  rsftp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
3306/tcp  open  mysql

Nmap done: 1 IP address (1 host up) scanned in 15.29 seconds
```

- **nmap -sU <target>**

UDP scan; checks UDP ports for responsive services.

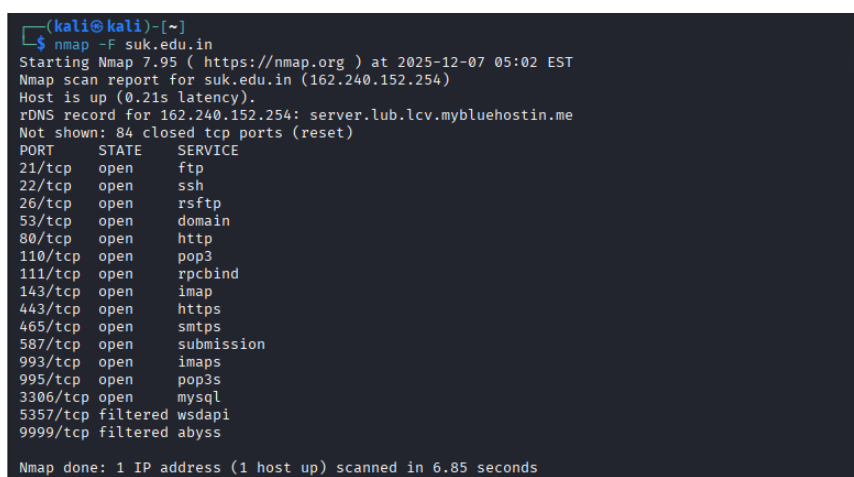


```
(kali@kali)-[~]
$ nmap -sU suk.edu.in
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:00 EST
Nmap scan report for suk.edu.in (162.240.152.254)
Host is up (0.050s latency).
rDNS record for 162.240.152.254: server.lub.lcv.mybluehostin.me
Not shown: 998 open|filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind

Nmap done: 1 IP address (1 host up) scanned in 19.23 seconds
(kali@kali)-[~]
```

- **nmap -F <target>**

Fast scan; scans only a smaller set of frequent ports.



```
(kali@kali)-[~]
$ nmap -F suk.edu.in
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:02 EST
Nmap scan report for suk.edu.in (162.240.152.254)
Host is up (0.21s latency).
rDNS record for 162.240.152.254: server.lub.lcv.mybluehostin.me
Not shown: 84 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
26/tcp    open  rsftp
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
143/tcp   open  imap
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
3306/tcp  open  mysql
5357/tcp  filtered wsddapi
9999/tcp  filtered abyss

Nmap done: 1 IP address (1 host up) scanned in 6.85 seconds
```

- **nmap -p 22,80,443 <target>**

Scans only the ports you specify.

```
(kali㉿kali)-[~]
└─$ nmap -p 22,21 suk.edu.in
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:03 EST
Nmap scan report for suk.edu.in (162.240.152.254)
Host is up (0.062s latency).
rDNS record for 162.240.152.254: server.lub.lcv.mybluehostin.me

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 0.56 seconds
```

- **nmap -O <target>**

Attempts to detect the operating system.

- **nmap -sV <target>**

Identifies service names and versions on open ports.

```
(kali㉿kali)-[~]
└─$ nmap -sV suk.edu.in
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-07 05:36 EST
Nmap scan report for suk.edu.in (162.240.152.254)
Host is up (0.0013s latency).
Other addresses for suk.edu.in (not scanned): 64:ff9b::a2f0:98fe
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Pure-FTPd
```

- **nmap -A <target>**

Aggressive scan : Enables OS detection, version detection, scripts, and traceroute.

3.Demonstration of Password Vulnerability. Tools: Hashcat and John The Ripper

HASHCAT

Open Kali Terminal (ignore this if hashcat is already installed, you can check it using the command :

hashcat --help (You can also view algorithms which hashcat uses in the list)

Else

→sudo apt update

→sudo apt upgrade

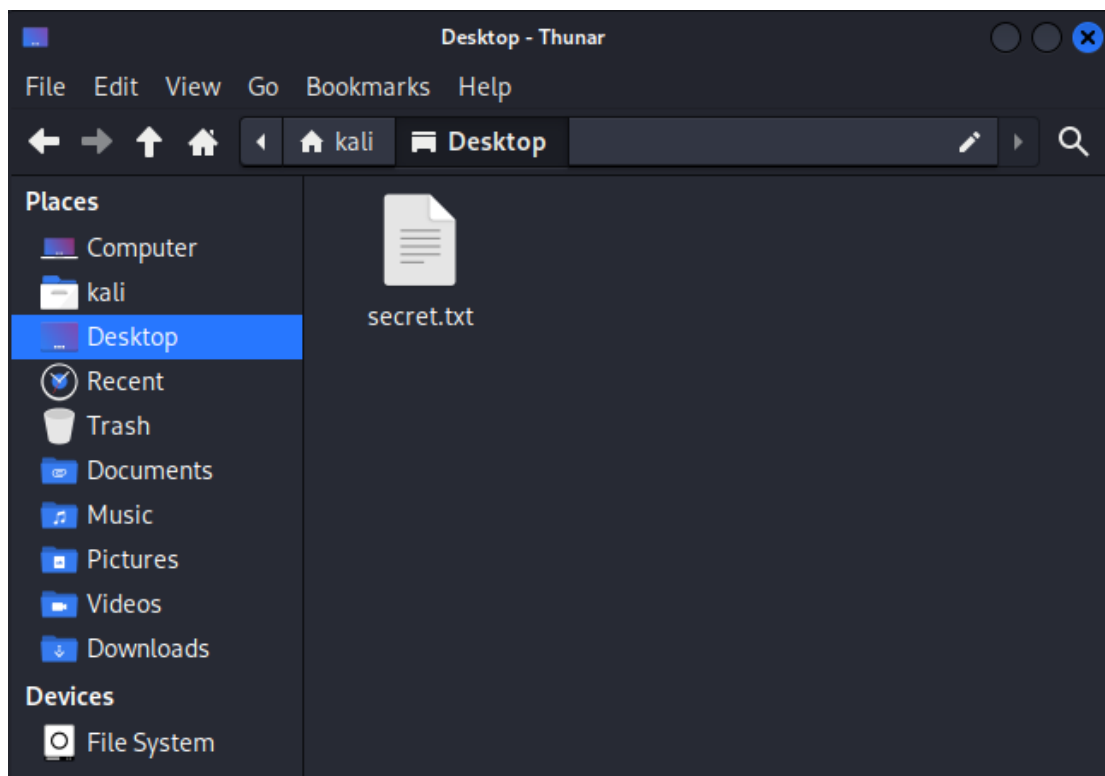
→sudo apt install hashcat

Step 1: Enter the command in kali terminal,

echo -n "password123" | sha256sum

Copy the Hash and save as secret.txt in Desktop

```
(kali@kali)-[~]
$ echo -n "password123" | sha256sum
ef92b778bafef771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f -
```



Step 2: Enter the below commands,

ls /usr/share/wordlists/

sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

```

(kali@kali)-[~]
$ ls /usr/share/wordlists/
amass  dirbuster  fasttrack.txt  john.lst  metasploit  rockyou.txt.gz  wfuzz
dirb   dnsmap.txt  fern-wifi     legion    nmap.lst    sqlmap.txt      wifite.txt

(kali@kali)-[~]
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:

(kali@kali)-[~]
$ ls /usr/share/wordlists/
amass  dirbuster  fasttrack.txt  john.lst  metasploit  rockyou.txt  wfuzz
dirb   dnsmap.txt  fern-wifi     legion    nmap.lst    sqlmap.txt   wifite.txt

```

Step 3: Change directory to Desktop (as secret.txt is saved in Desktop) and enter the below command.

hashcat -m 1400 -a 0 secret.txt /usr/share/wordlists/rockyou.txt

```

(kali@kali)-[~]
$ cd Desktop

(kali@kali)-[~/Desktop]
$ hashcat -m 1400 -a 0 secret.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP,
DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====
* Device #1: cpu-haswell-13th Gen Intel(R) Core(TM) i5-13500, 1438/2941 MB (512 MB allocatable),
3MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.

```

```
kali@kali: ~/Desktop x kali@kali: ~ x kali@kali: ~ x
ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 1 sec

ef92b778bafef771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f:password123

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1400 (SHA2-256)
Hash.Target.....: ef92b778bafef771e89245b89ecbc08a44a4e166c06659911881 ... 73e94f
Time.Started.....: Sun Dec 7 06:18:10 2025 (0 secs)
Time.Estimated...: Sun Dec 7 06:18:10 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 24622 H/s (0.10ms) @ Accel:256 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1536/14344385 (0.01%)
Rejected.....: 0/1536 (0.00%)
Restore.Point....: 768/14344385 (0.01%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: football1 → mexico1
Hardware.Mon.#1..: Util: 26%

Started: Sun Dec 7 06:17:50 2025
Stopped: Sun Dec 7 06:18:11 2025
```

Result: Hashcat cracked the password from secret.txt comparing the hash to rockyou.txt wordlists.

JOHN THE RIPPER

sudo apt update
sudo apt install john

Enter the below command,

john --format=raw-sha256 --wordlists=/usr/share/wordlists/rockyou.txt secret.txt

(**Note:** Secret.txt contains the hash , original string : password123)

We are cracking this using John the ripper tool.)

```
(kali@kali)~[~/Desktop]
$ john --format=raw-sha256 --wordlist=/usr/share/wordlists/rockyou.txt secret.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA256 [SHA256 256/256 AVX2 8x])
Warning: poor OpenMP scalability for this hash type, consider --fork=3
Will run 3 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password123 (?)
1g 0:00:00:00 DONE (2025-12-07 06:26) 16.66g/s 819200p/s 819200c/s 819200C/s 123456..trudy
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably
Session completed.
```

Result:

Enter the Command,
John --show --format=raw-sha256 secret.txt

(This shows cracked password)

```
(kali㉿kali)-[~/Desktop]
└─$ john --show --format=raw-sha256 secret.txt
?:password123

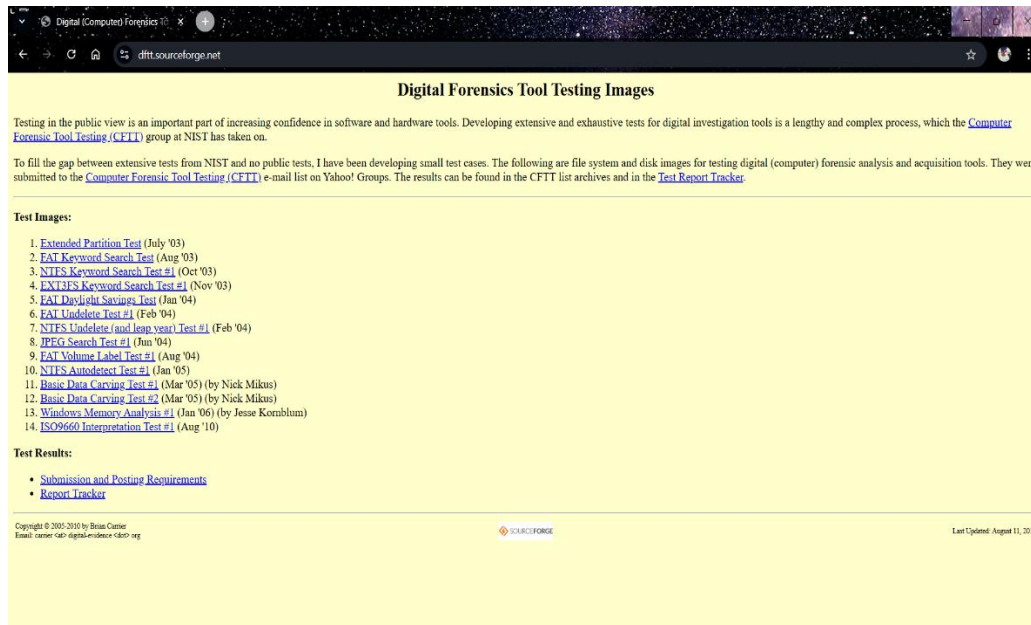
1 password hash cracked, 0 left
```

4. Master the Fundamentals of Digital Forensics and Evidence collection using autopsy.

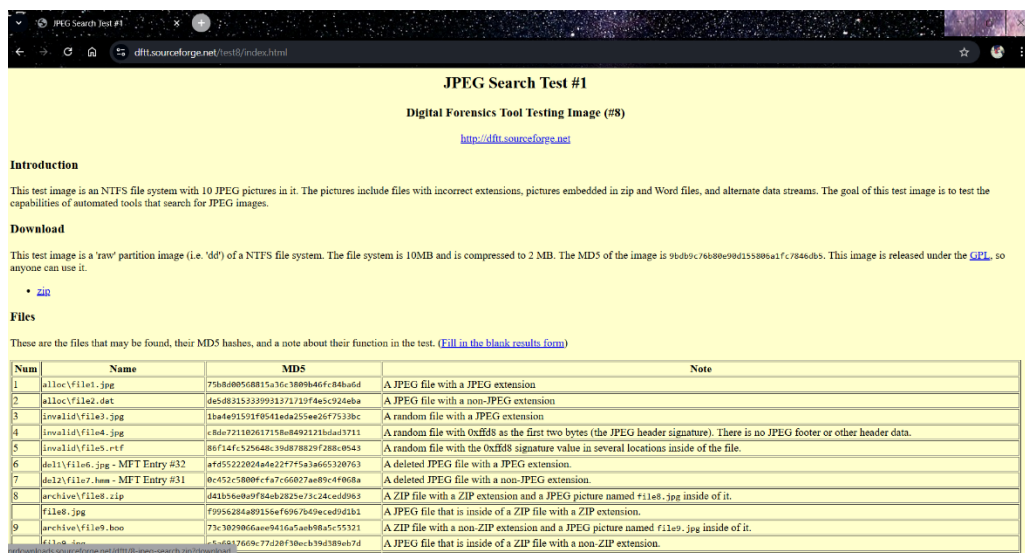
Autopsy is a digital forensics tool that lets investigators load a disk image, automatically extract system and user data, recover deleted files, view activity timelines, search for keywords, and collect important evidence, all in one place, and then export a simple investigation report.

Step 1: Download Autopsy from - <https://www.autopsy.com/download/>

Step 2: In chrome search dftt.sourceforge.net and click on 8.Jpeg search test.



Step 3: Click on the zip and download it, then extract it.

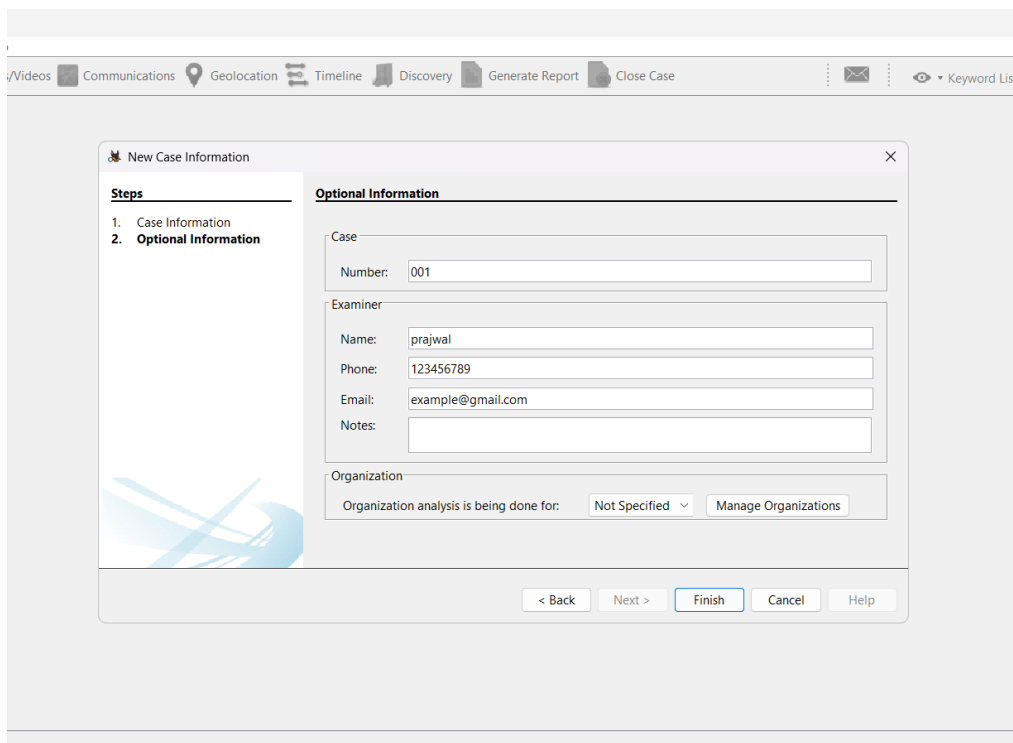
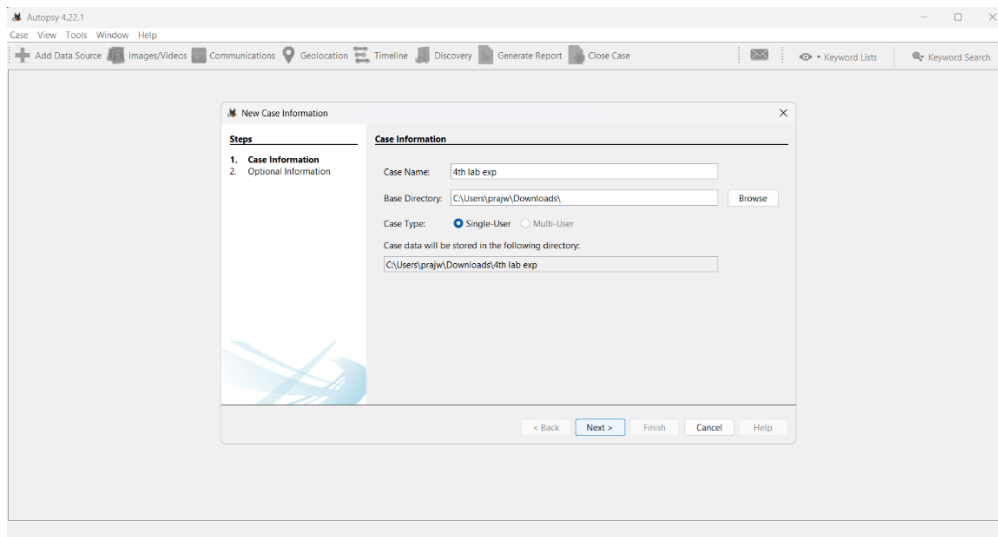


Step 4: Open Autopsy

(And follow steps as shown in the images)

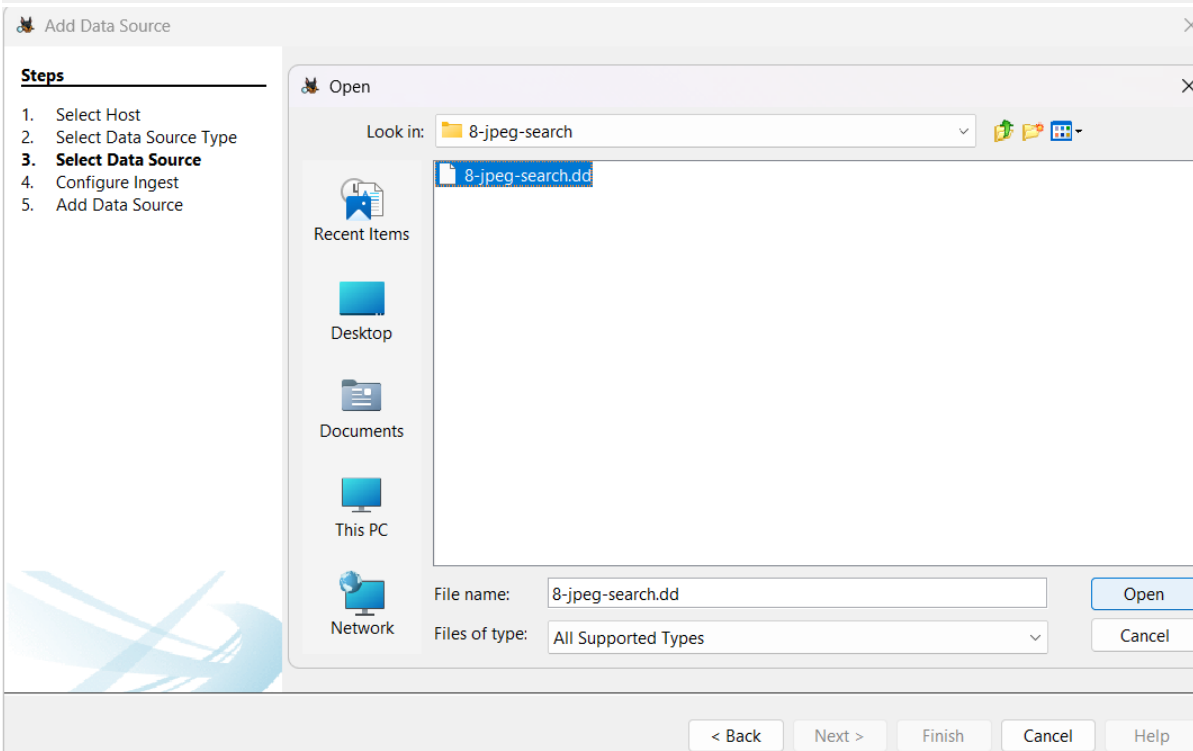
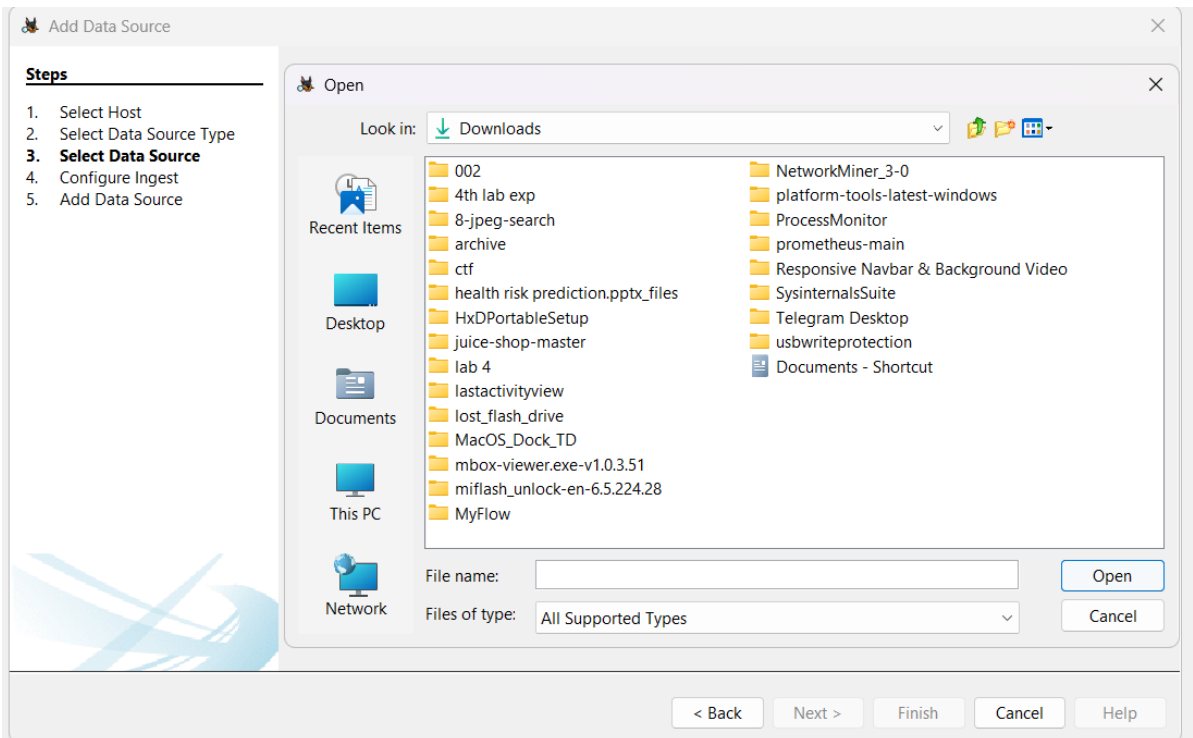
Select New case → add case name, case number, fill details like Name, phone and mail. → Finish

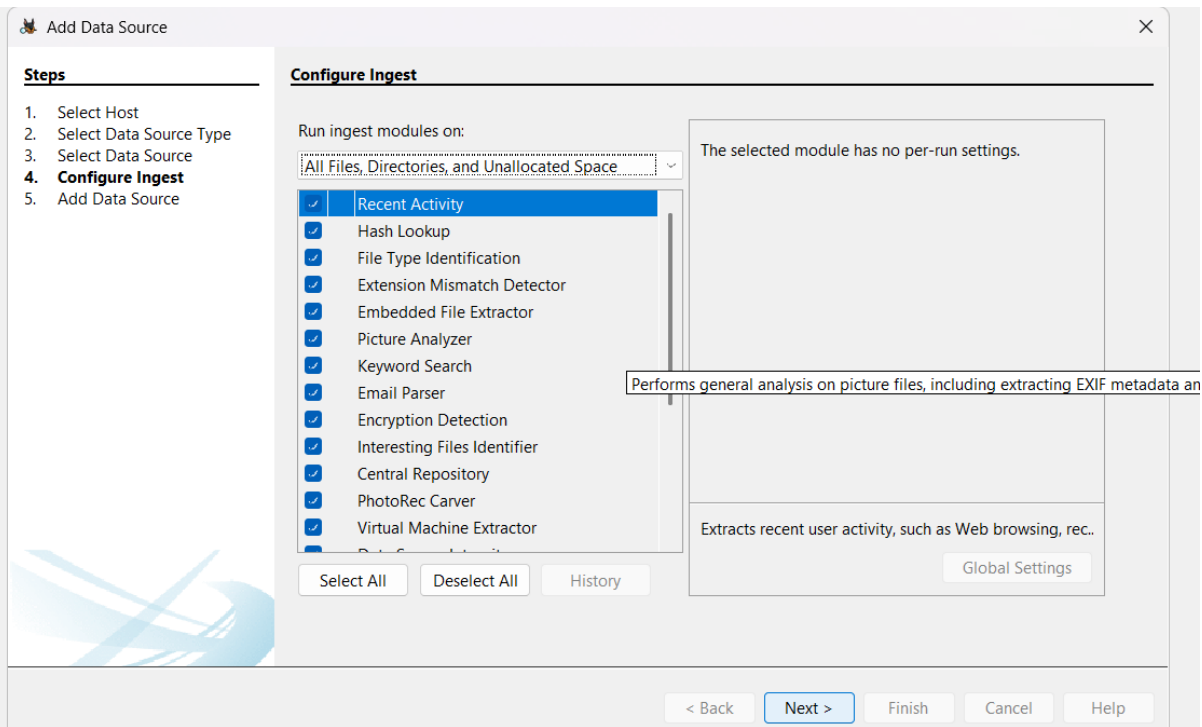
Sharnbasva University, FET(Co-Ed), Dept.of AI&DS



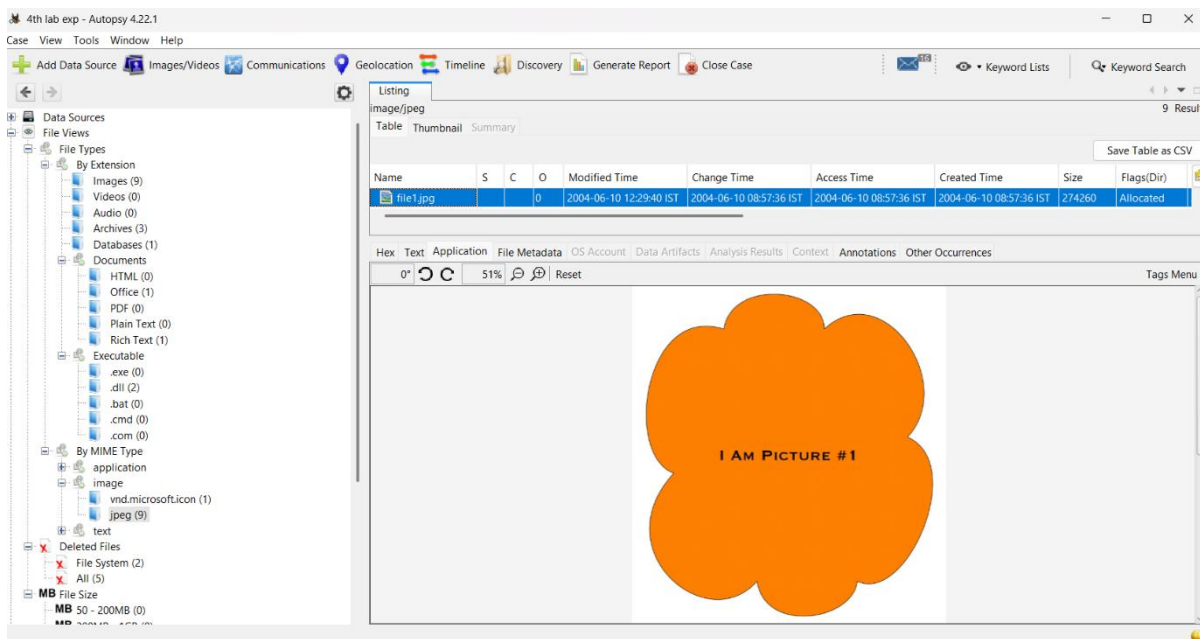
Step 5: Now to add source

Select Disk image → Browse the downloaded image which is of type .dd → Finish





Step 6: Analyze the results properly and find three hidden pictures.



4th lab exp - Autopsy 4.22.1

Case View Tools Window Help

Add Data Source Images/Videos Communications Geolocation Timeline Discovery Generate Report Close Case

Listing

Extension Mismatch Detected 2 Results

Table Thumbnail Summary

Save Table as CSV

Source Name	S	C	O	Source Type	Score	Conclusion	Configuration	Justification	Extension	MIME Type
file2.dat			0	File	Likely Notable			File has MIME type of image/jpeg	.dat	image/jpeg

Hex Text Application File Metadata OS Account Data Artifacts Analysis Results Context Annotations Other Occurrences

0% 105% Reset

Tags Menu

I AM PICTURE #2

4th lab exp - Autopsy 4.22.1

Case View Tools Window Help

Add Data Source Images/Videos Communications Geolocation Timeline Discovery Generate Report Close Case

Listing

File System 2 Results

Table Thumbnail Summary

Save Table as CSV

Name	S	C	O	Modified Time	Change Time	Access Time	Created Time	Size	Flags(Dir)	Flags
file6.jpg				2004-06-10 12:18:08 IST	2004-06-10 08:58:00 IST	2004-06-10 08:58:00 IST	2004-06-10 08:58:00 IST	175630	Unallocated	Un

Hex Text Application File Metadata OS Account Data Artifacts Analysis Results Context Annotations Other Occurrences

Reset

Tags Menu

I AM PICTURE #3

4th lab exp - Autopsy 4.22.1

Case View Tools Window Help

Add Data Source Images/Videos Communications Geolocation Timeline Discovery Generate Report Close Case

Listing

Metadata 1 Results

Table Thumbnail Summary

Save Table as CSV

Source Name	S	C	O	Owner	Date Modified	Date Created	Program Name	User ID	Data Source
file12.doc				Brian Carrier	2004-06-10 02:20:00 IST	2004-06-10 02:20:00 IST	Microsoft Word 10.1	Brian Carrier	8-jpeg-search.dd

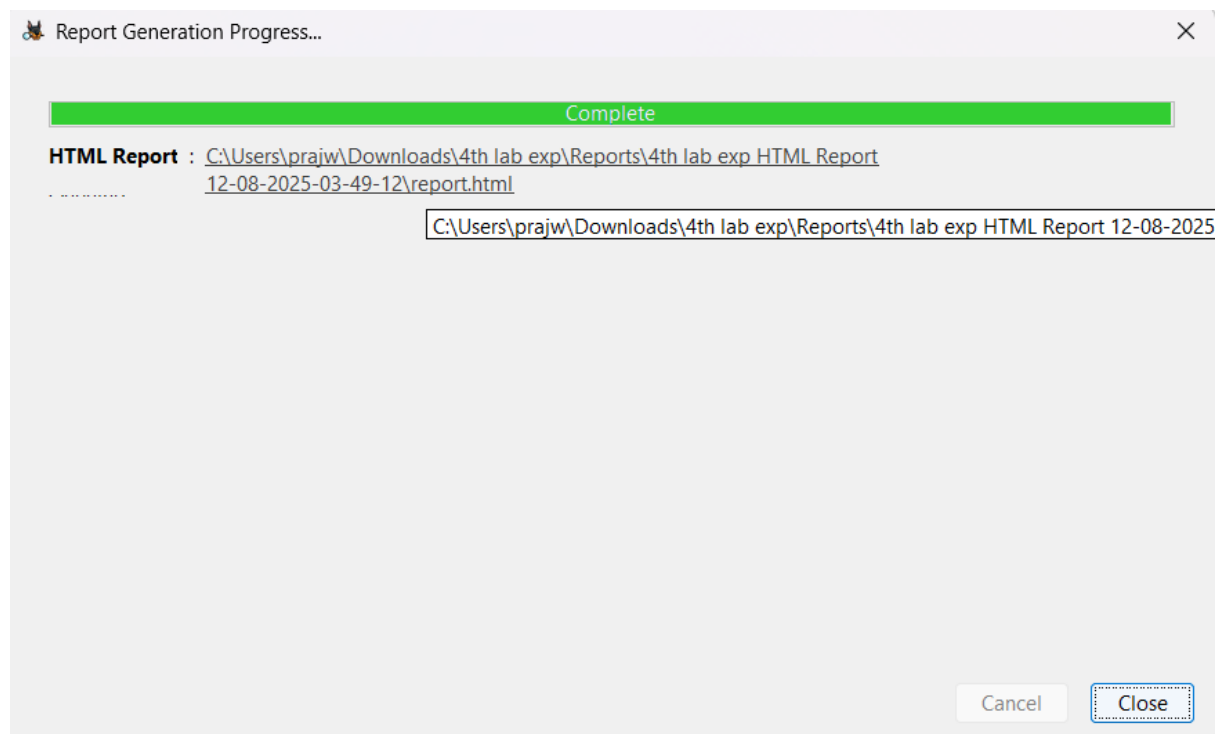
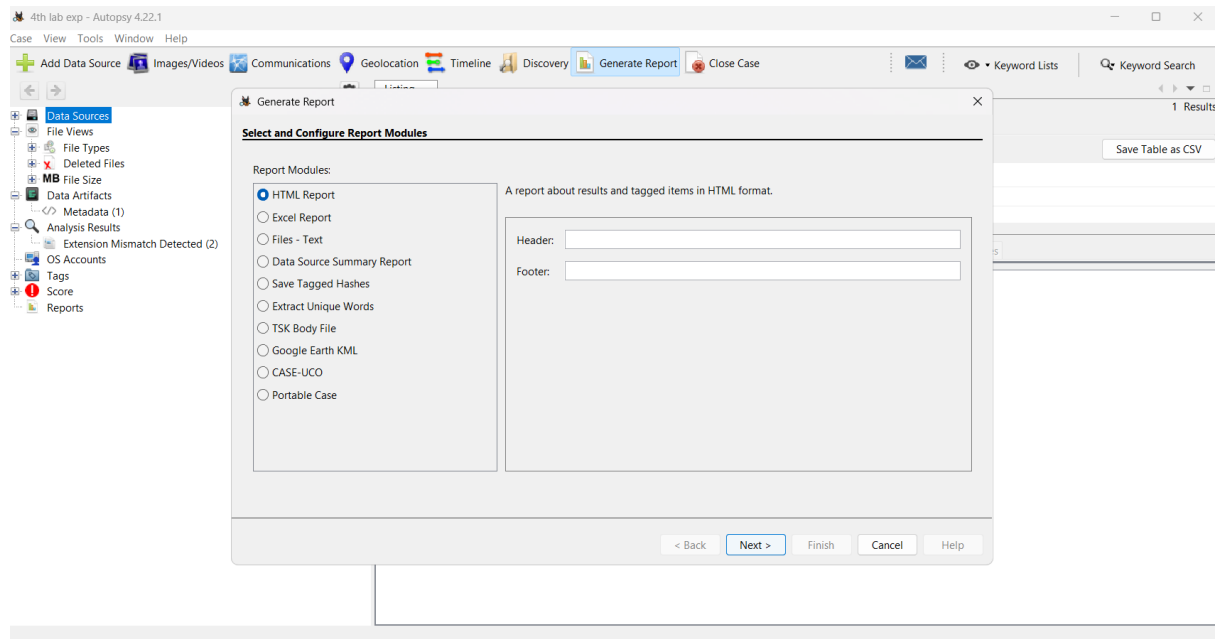
Hex Text Application Source File Metadata OS Account Data Artifacts Analysis Results Context Annotations Other Occurrences

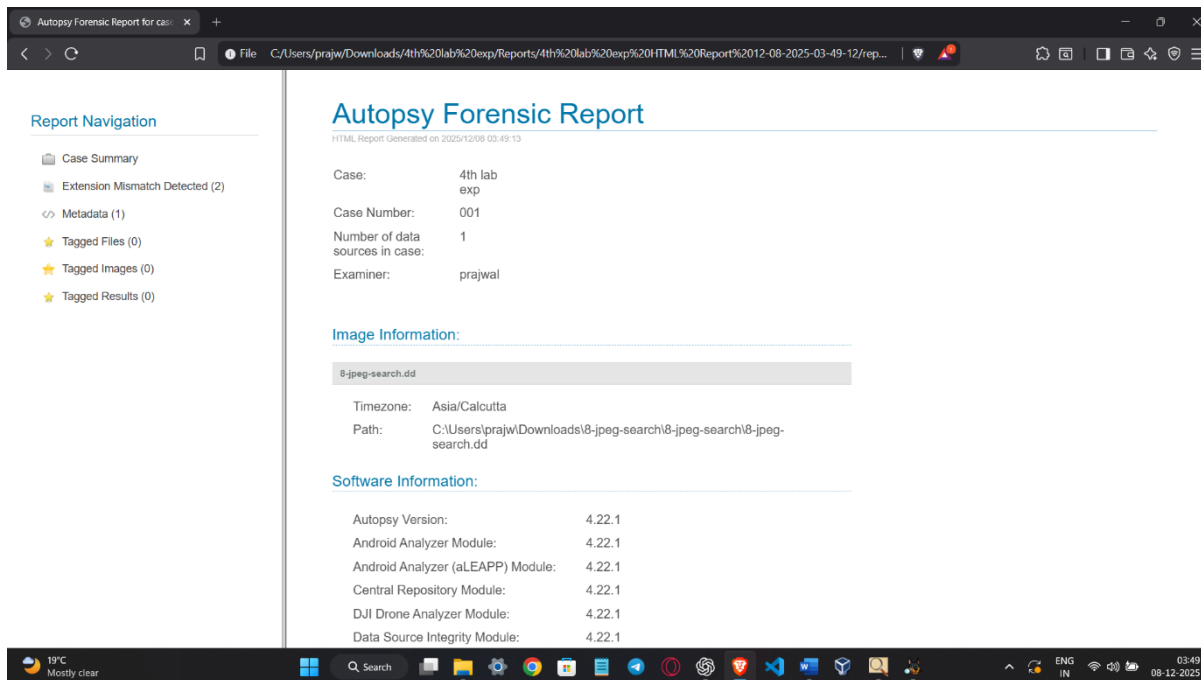
Result: 1 of 1 Result

Metadata

Type	Value	Source(s)
Owner	Brian Carrier	org.sleuthkit.aut
Date Modified	2004-06-10 02:20:00 IST	org.sleuthkit.aut
Date Created	2004-06-10 02:20:00 IST	org.sleuthkit.aut
Program Name	Microsoft Word 10.1	org.sleuthkit.aut
User ID	Brian Carrier	org.sleuthkit.aut
Source File Path	/img_8-jpeg-search.dd/misc/file12.doc	
Artifact ID	-9223372036854775805	

Step 7: Generate report and view the report.



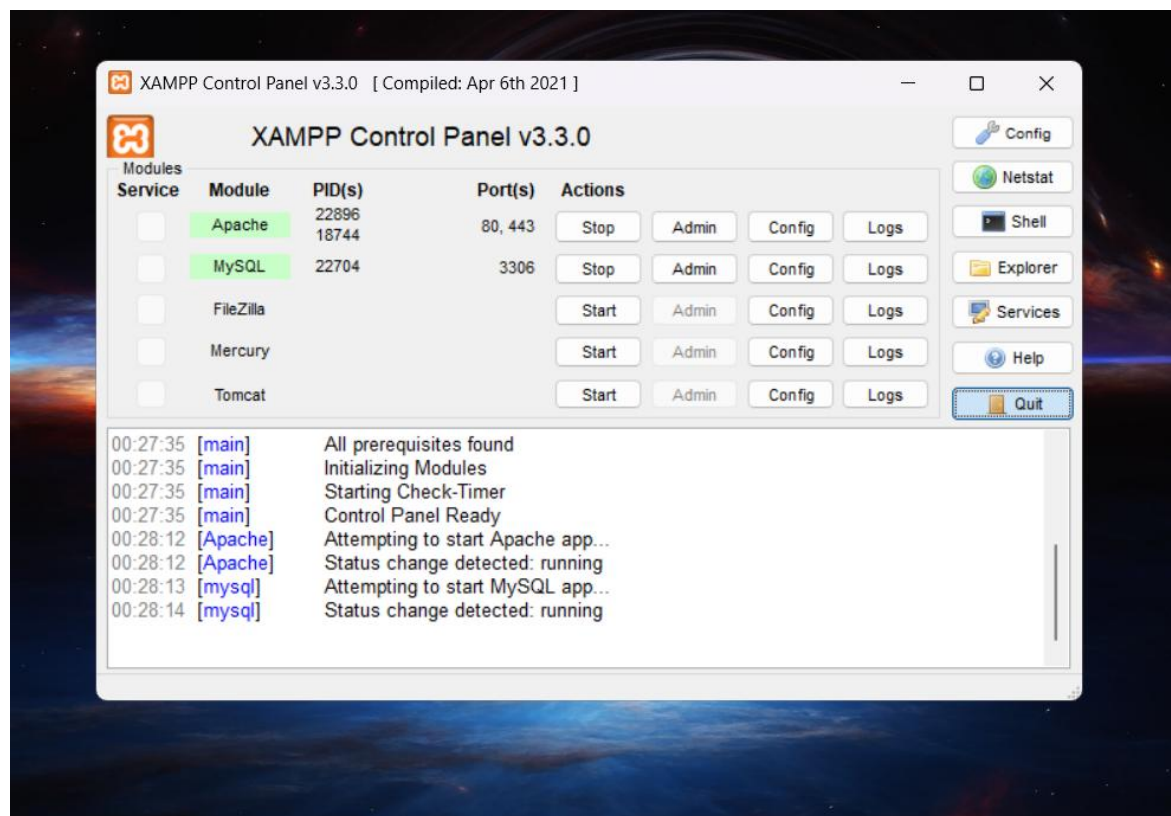


Result: The activity built practical skill in using Autopsy to load a forensic image, analyze extracted artifacts, locate hidden pictures, and generate an investigation report, demonstrating how digital evidence is systematically examined and documented.

5. Exploit SQL injection in an intentionally vulnerable web app (DVWA/OWASP Juice Shop) and document PoC and fixes.

Step 1: Download and Install XAMPP from <https://www.apachefriends.org/download.html>

Step 2: Open XAMPP and Start Apache and SQL



Step 3: Download DVWA

Download DVWA ZIP from GitHub (<https://github.com/digininja/DVWA>)

Extract it into:

C:\xampp\htdocs\dvwa

Step 4: Configure DVWA

Go to:

C:\xampp\htdocs\dvwa\config

Rename:

config.inc.php.dist → config.inc.php

Open config.inc.php and set:

`$_DVWA['db_user'] = 'root';`

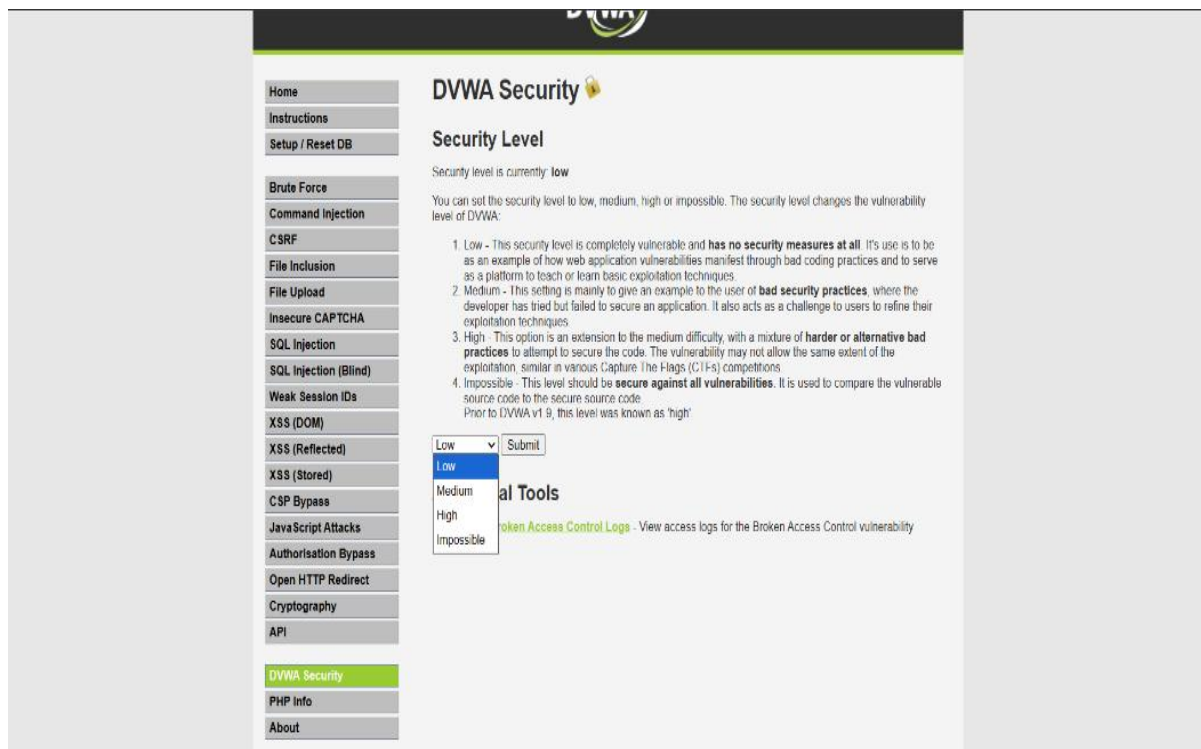
`$_DVWA['db_password'] = '';`

Step 5: Start any web browser and open- <http://localhost/dvwa/login.php>

Step 6: Login with default credentials, username – admin , password – password.



Step 7: Under DVWA Security, set security level to low.



Step 8: Now goto Sql injection section, enter the below Boolean checks

1' OR '1'='1 forces the query's WHERE clause to always evaluate true.

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The left sidebar contains a menu with various security vulnerabilities listed. The main content area is titled "Vulnerability: SQL Injection". It features a "User ID:" input field and a "Submit" button. Below the input field, the results of the query are displayed in red text. The results show that the query successfully retrieved user information for ID 1, including the first name and surname. The "More Information" section provides links to external resources for further learning about SQL injection.

Vulnerability: SQL Injection

User ID: Submit

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

1' OR 1=1 -- does the same and comments out the rest of the query.

This screenshot shows the DVWA interface with the same "Vulnerability: SQL Injection" section. The "User ID:" input field is filled with the payload "1' OR 1=1 --". The results displayed below the input field show that the query successfully retrieved user information for ID 1, including the first name and surname. The "More Information" section provides links to external resources for further learning about SQL injection.

Vulnerability: SQL Injection

User ID: Submit

ID: 1' OR 1=1 --
First name: admin
Surname: admin

ID: 1' OR 1=1 --
First name: Gordon
Surname: Brown

ID: 1' OR 1=1 --
First name: Hack
Surname: Me

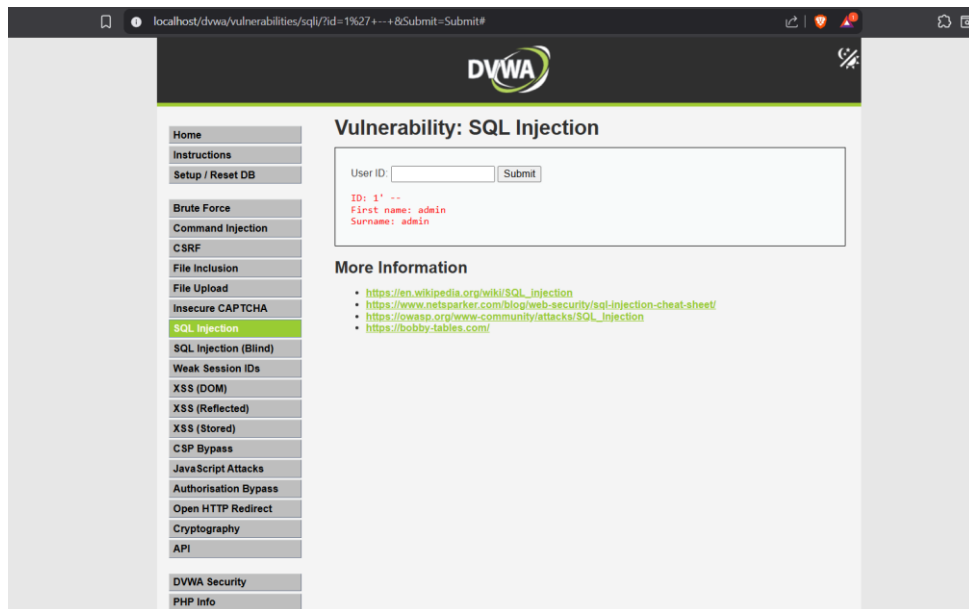
ID: 1' OR 1=1 --
First name: Pablo
Surname: Picasso

ID: 1' OR 1=1 --
First name: Bob
Surname: Smith

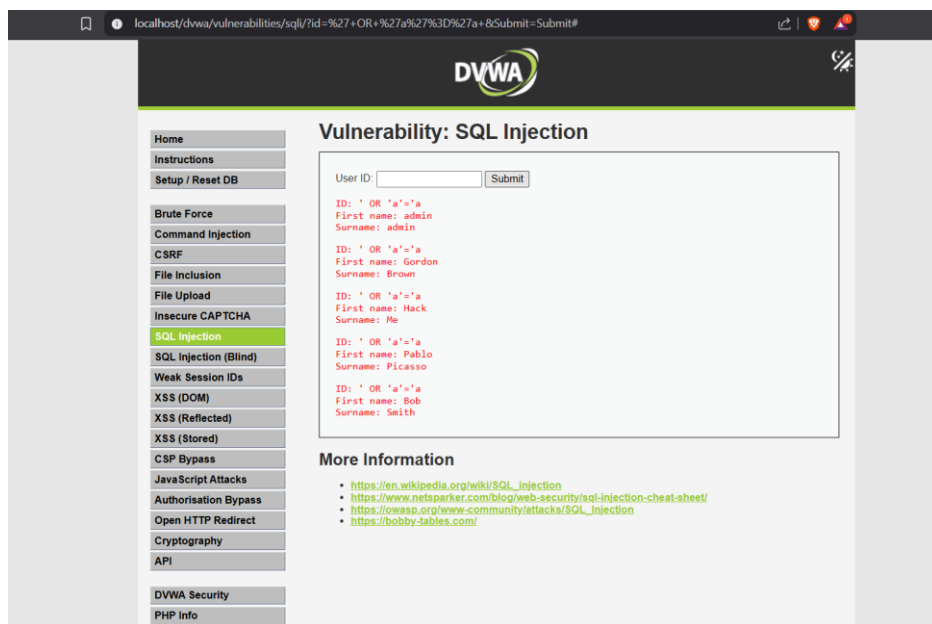
More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

1' -- terminates the value and removes the trailing SQL so the query still returns data.



OR 'a'='a' injects a universally true comparison to bypass filtering.



Step 9: At last Open Xampp and Stop Apache and SQL, then close it.

6. Capture network traffic (Wireshark) for given Scenarios, identify suspicious flows, and suggest detection rules.

Step 1: Download and install Wireshark from <https://www.wireshark.org/download.html>

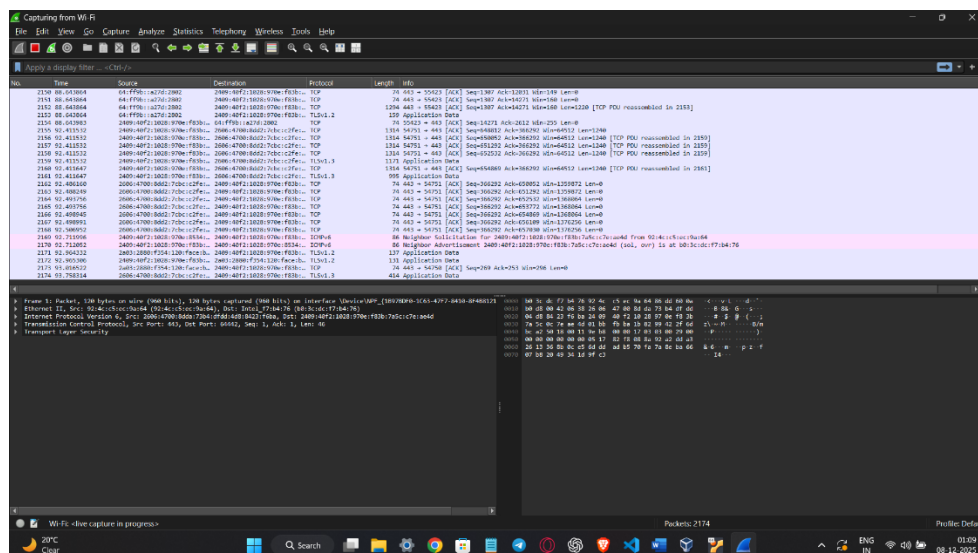
Step 2: Open Wireshark and select eth0 if you are on Ethernet, else Wi-Fi

Step 3: Network traffic capturing is started

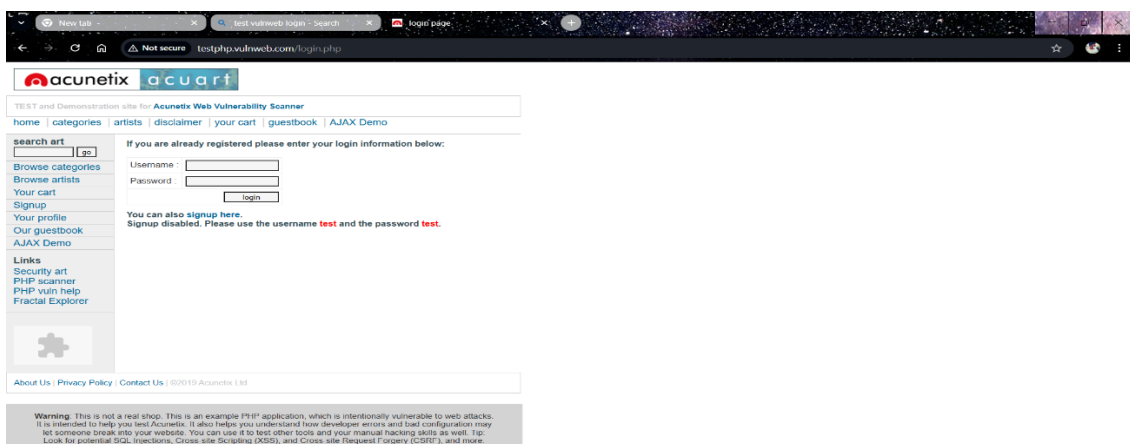
→ **Top pane** displays each captured packet with time, source, destination, protocol, and summary so you can scan overall traffic flow.

→ **Left Bottom pane** breaks down the selected packet into its protocol layers (Ethernet, IP, TCP/UDP, application layer) so you can see exactly how the packet is structured and what fields it contains.

→ **Right Bottom pane** shows the packet's raw hexadecimal and ASCII bytes so you can verify the unprocessed data exactly as it was captured.



Step 4: Start any web browser and open - <http://testphp.vulnweb.com/login.php>



Step 6: In Wireshark filterbox search for **Http**

Step 7: Find Post method and select it, In Bottom left pane

Under HTML format u can see `username` and `psswd` which u have entered in the website.

Result:

As Http is not secure protocol, data packets travel in plain text. Through Wireshark we can capture those packets and analyze the packets.

7. Embed/extract hidden data in files (image/audio/doc) and Evaluate detectability and forensic hints.

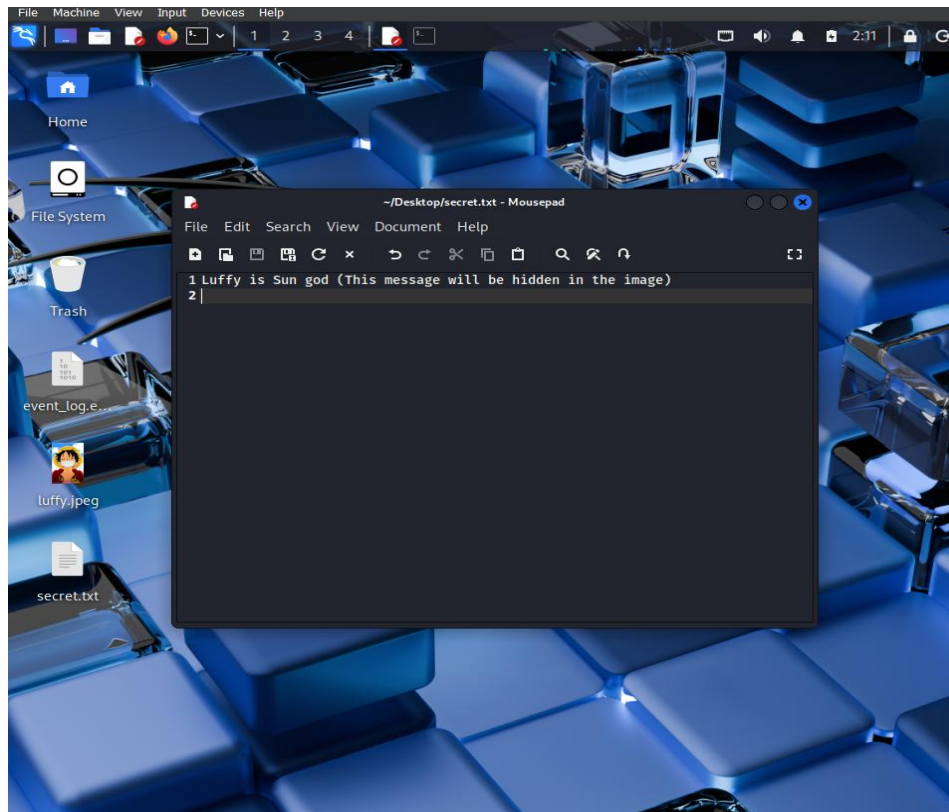
Steghide is a command-line steganography tool that hides or extracts data inside certain media files (like JPEG or WAV) without visibly altering the carrier file.

→sudo apt update

→sudo apt install steghide

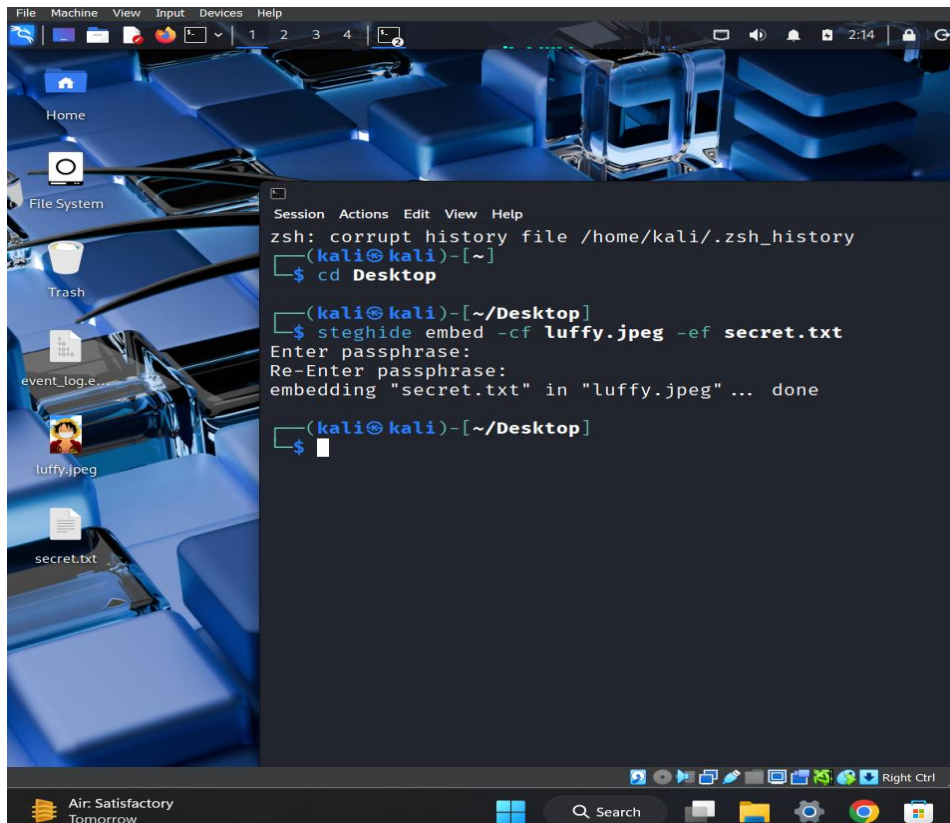
Step 1: Download any image and save it in Desktop. (save it as anonymous.jpeg)

Step 2: Also create a secret.txt and add some text in Desktop.



Step 3: Open terminal and enter the below command to embed message in the image,

steghide embed -cf anonymous.jpeg -ef secret.txt

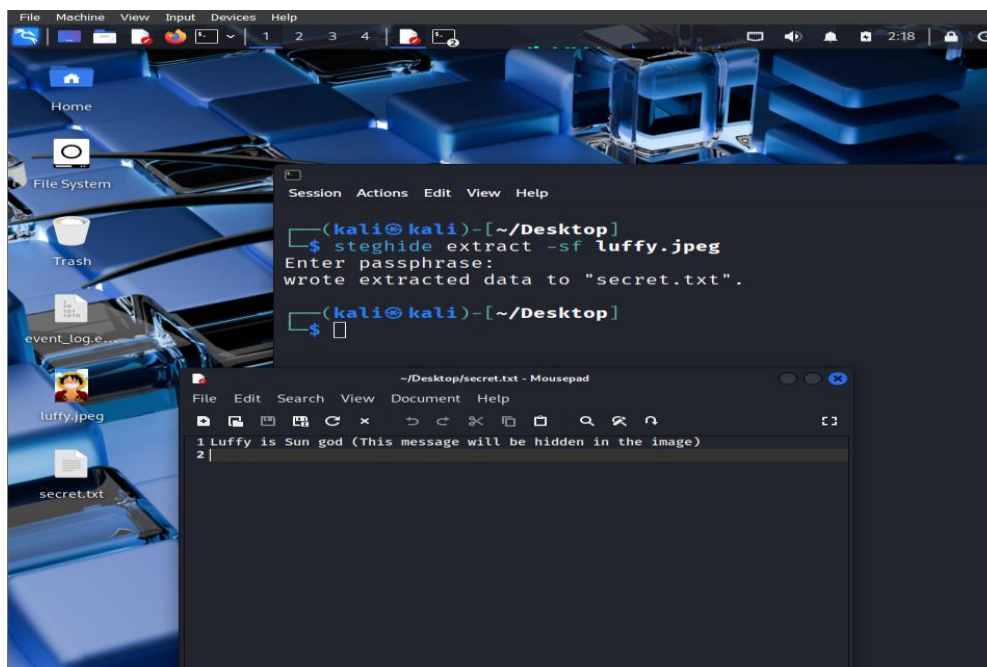


Step 4: Delete the secret.txt (As the text is hidden into image)

Step 5: Open terminal and enter the below command to extract the secret message

steghide extract -sf anonymous.jpeg

(secret.txt will appear again, now u can view the message)

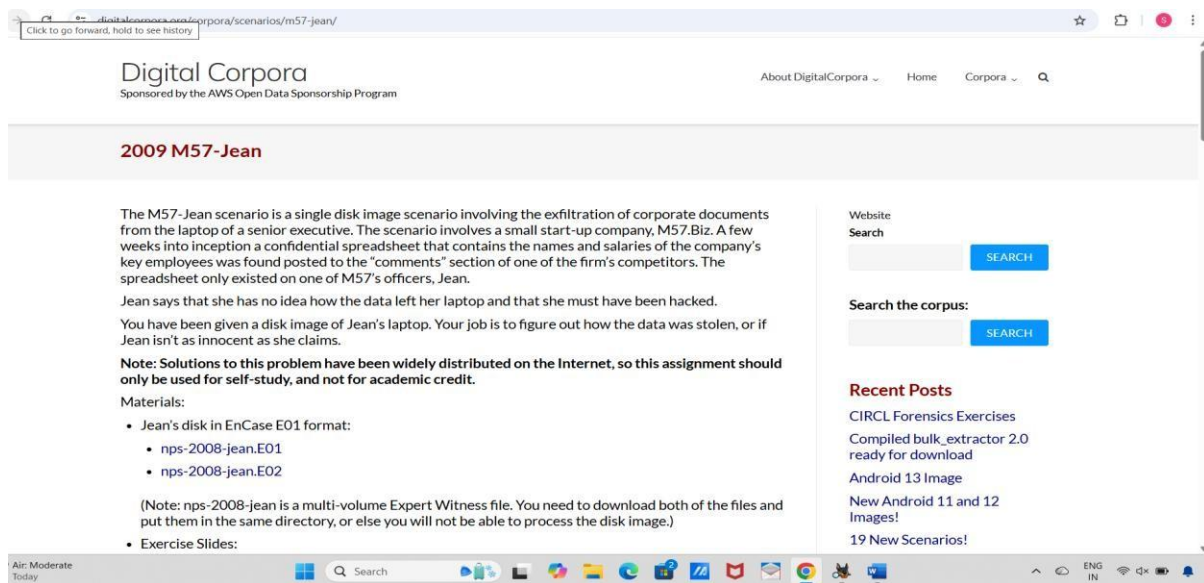


8. Analyze a provided memory dump using Volatility to identify processes, network connections, and possible malicious artifacts.

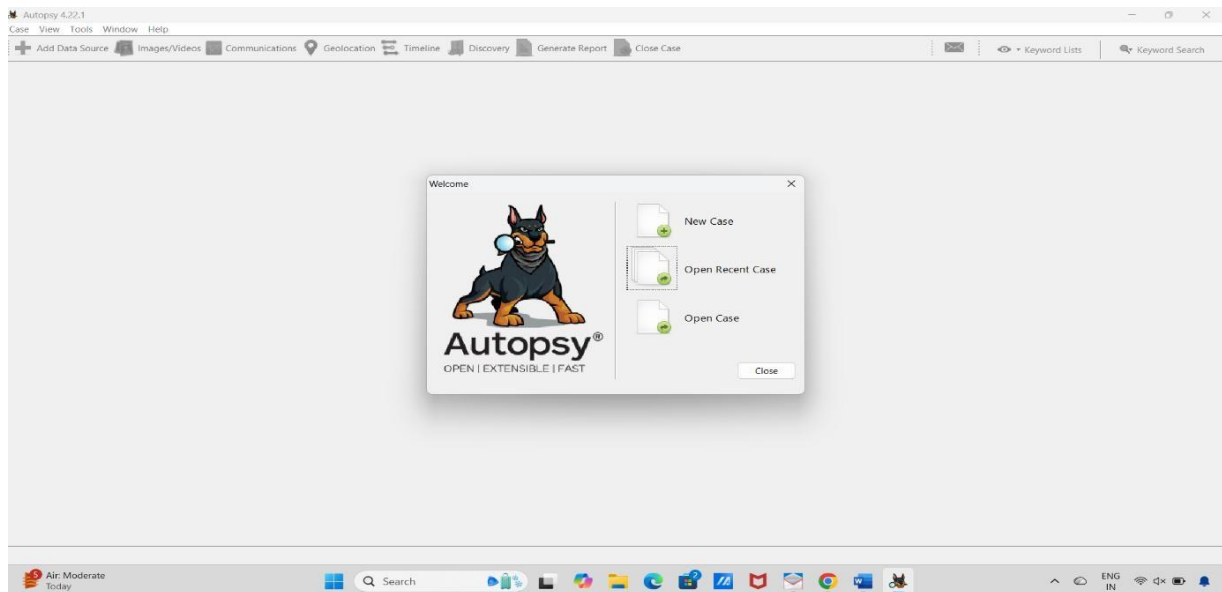
Case Analysis

Now, we will see how we can use Autopsy for investigating a hard drive. For that, we will go through a scenario most of us come across while studying digital forensics, and that is the scenario of 2009 M57-Jean.

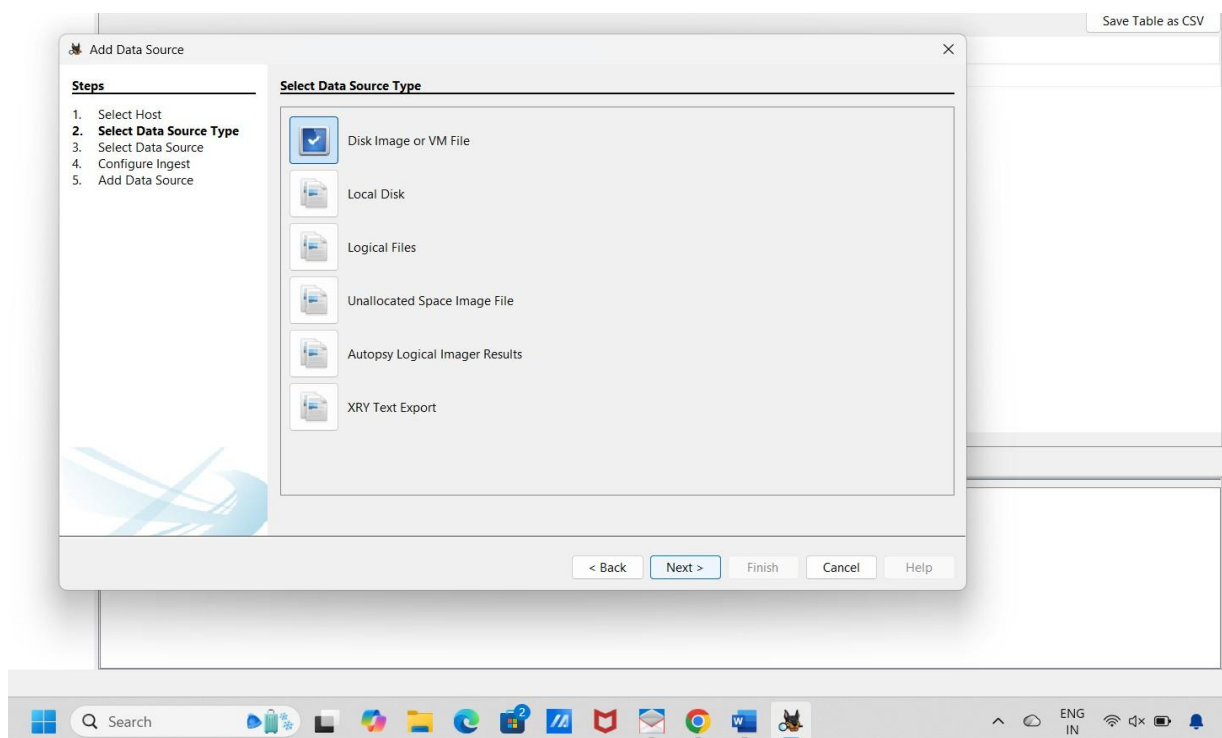
The image displays the complete scenario:



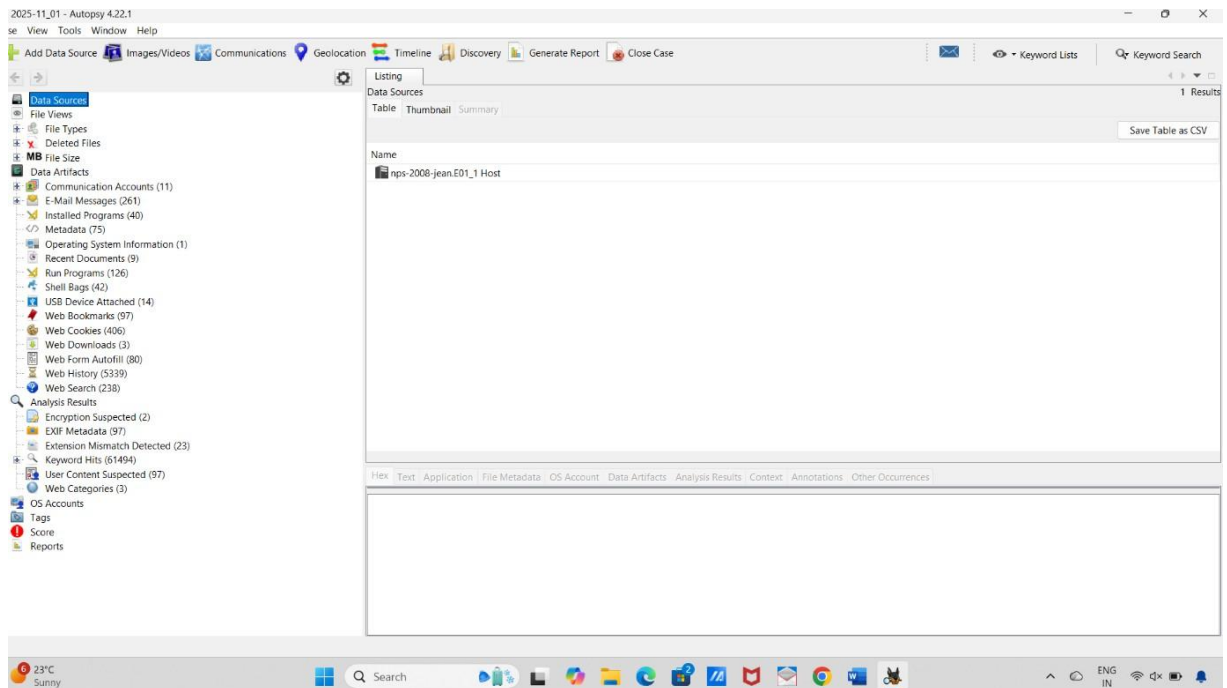
Start the Autopsy software and choose between the new case, open Recent Case or open case



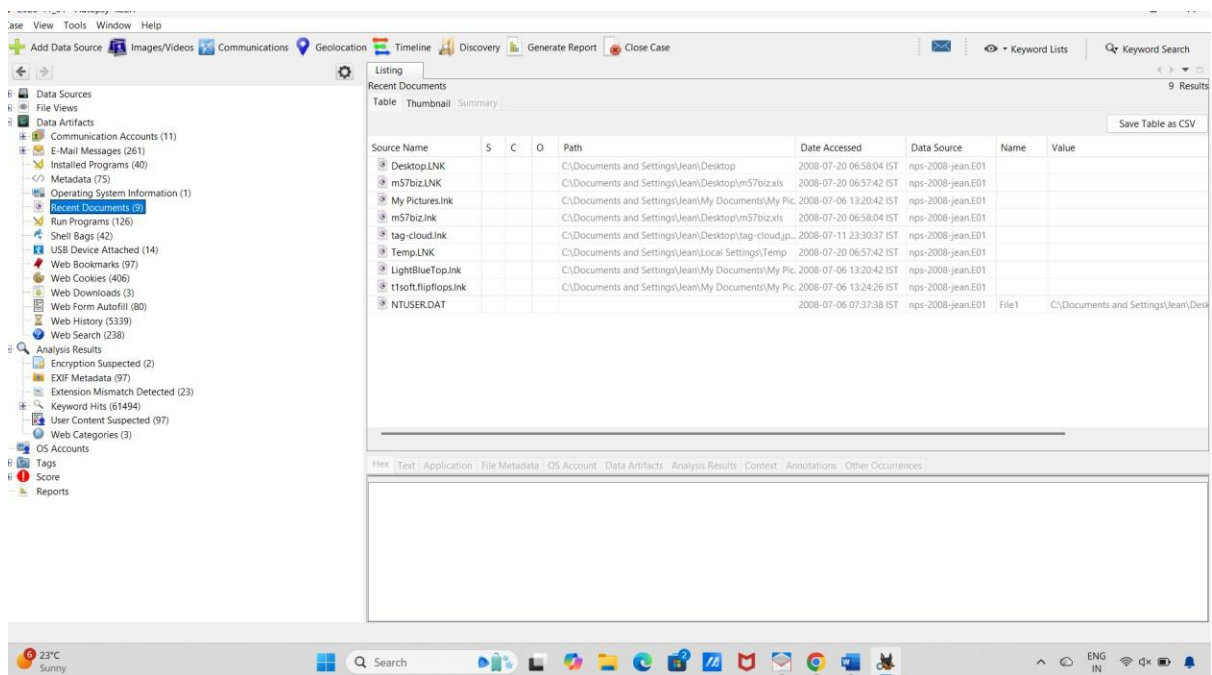
Enter the case information like the case number and location it, is to be saved in (if it's new case). The case number and examiner details may also enter.



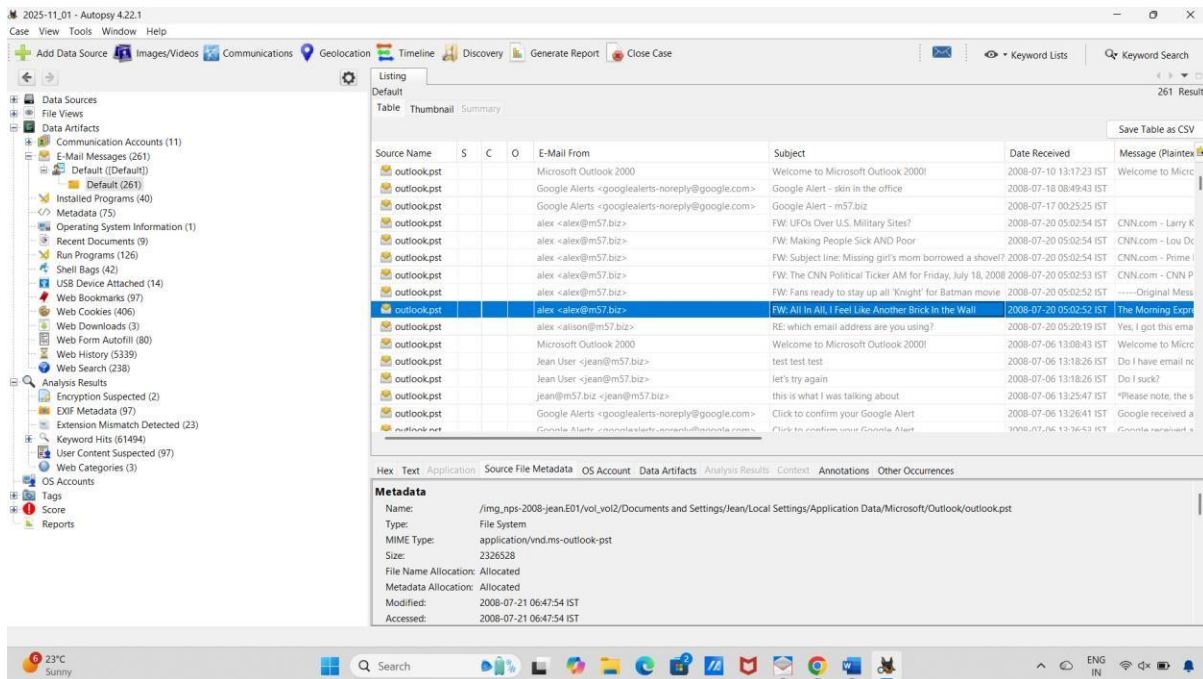
The ingested file nps-2008-jean.E01 and nps-2008-jean.E02 can be viewed



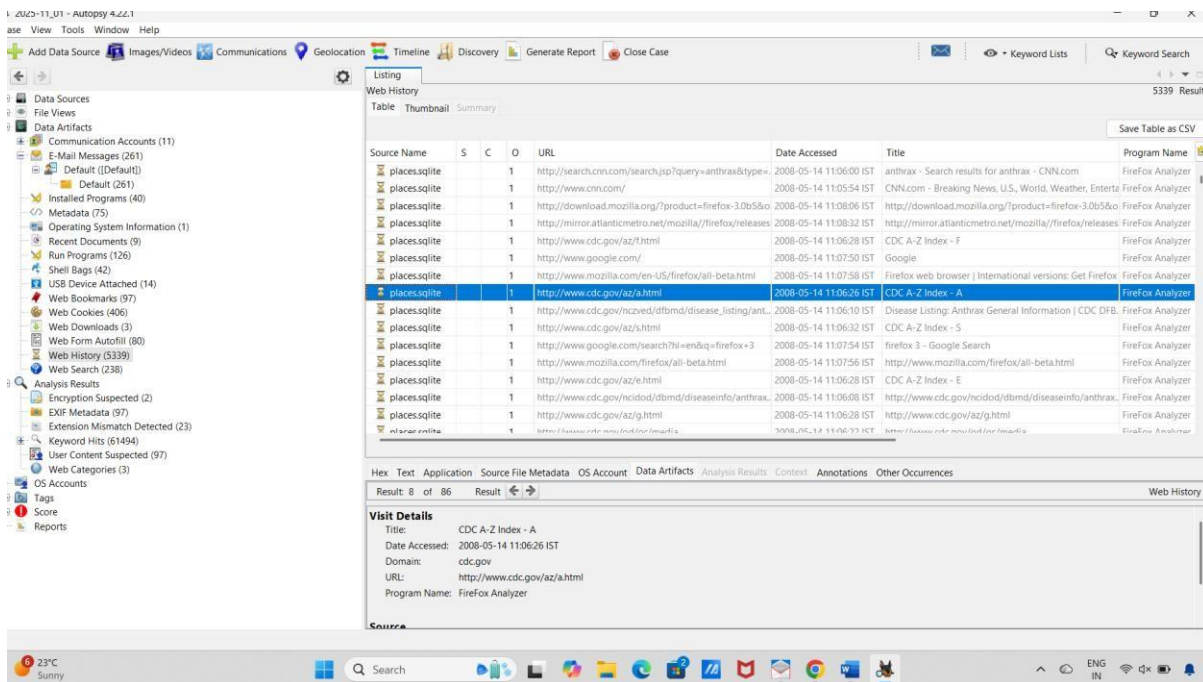
The Recent documents can be viewed.



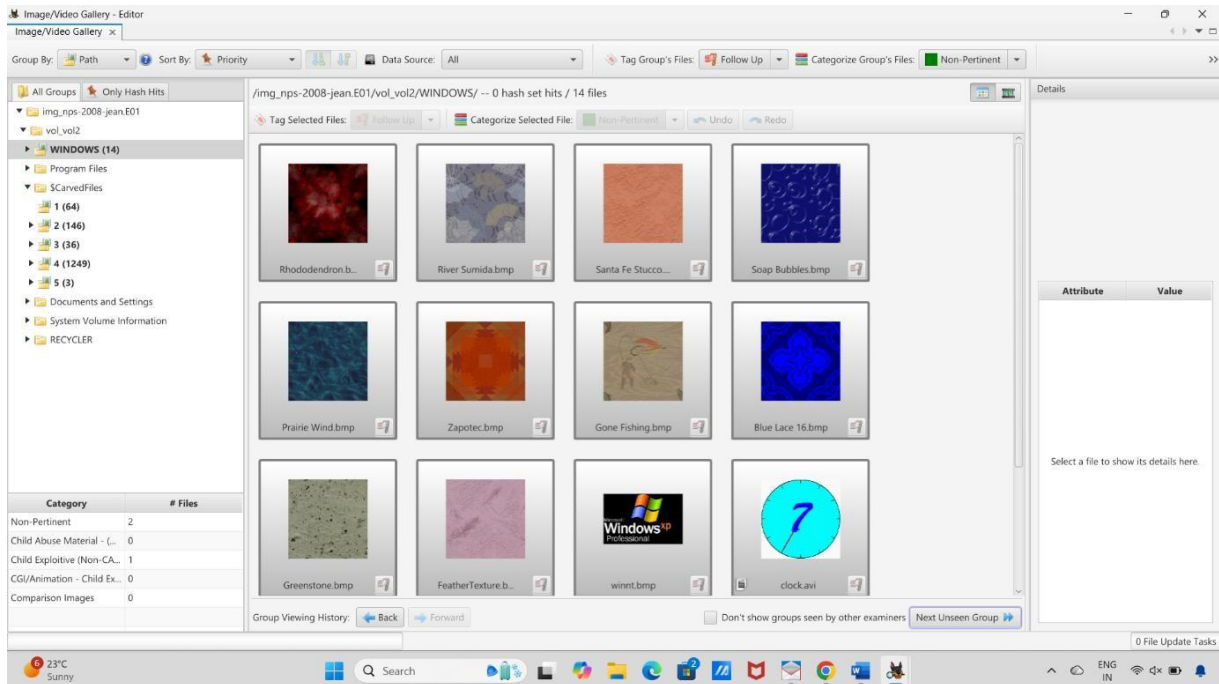
The mail from and to along with subject and meta data can be viewed.



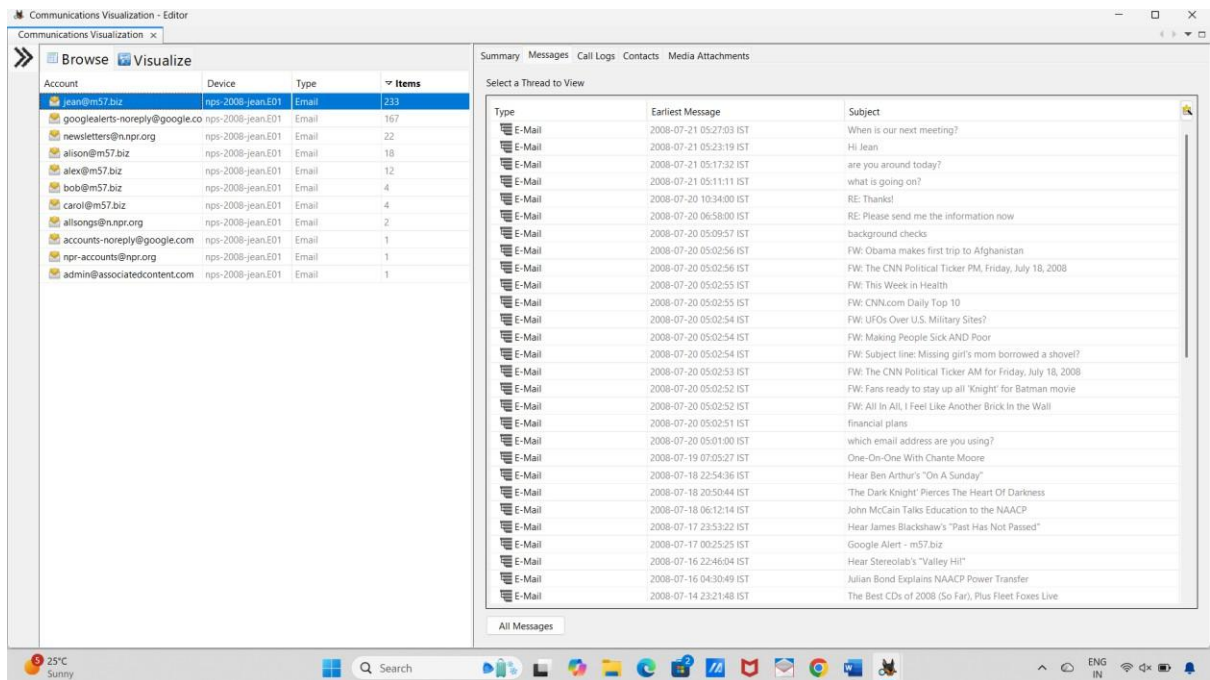
The web History can be viewed.



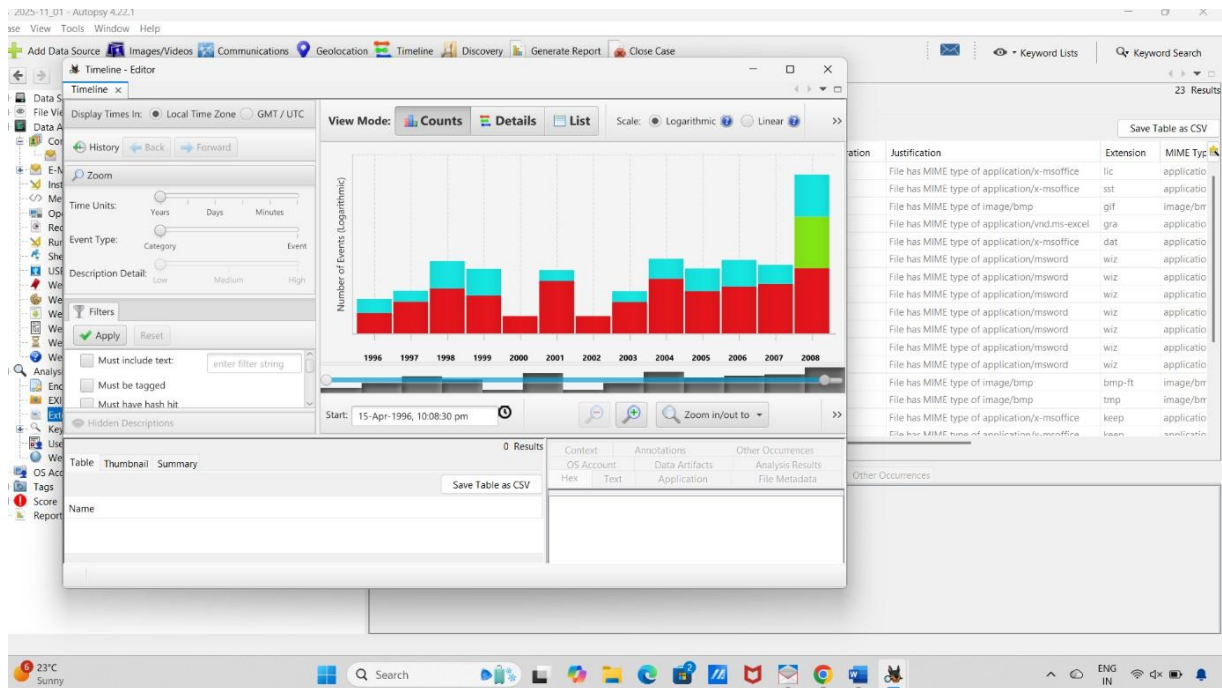
The image and video can be viewed.



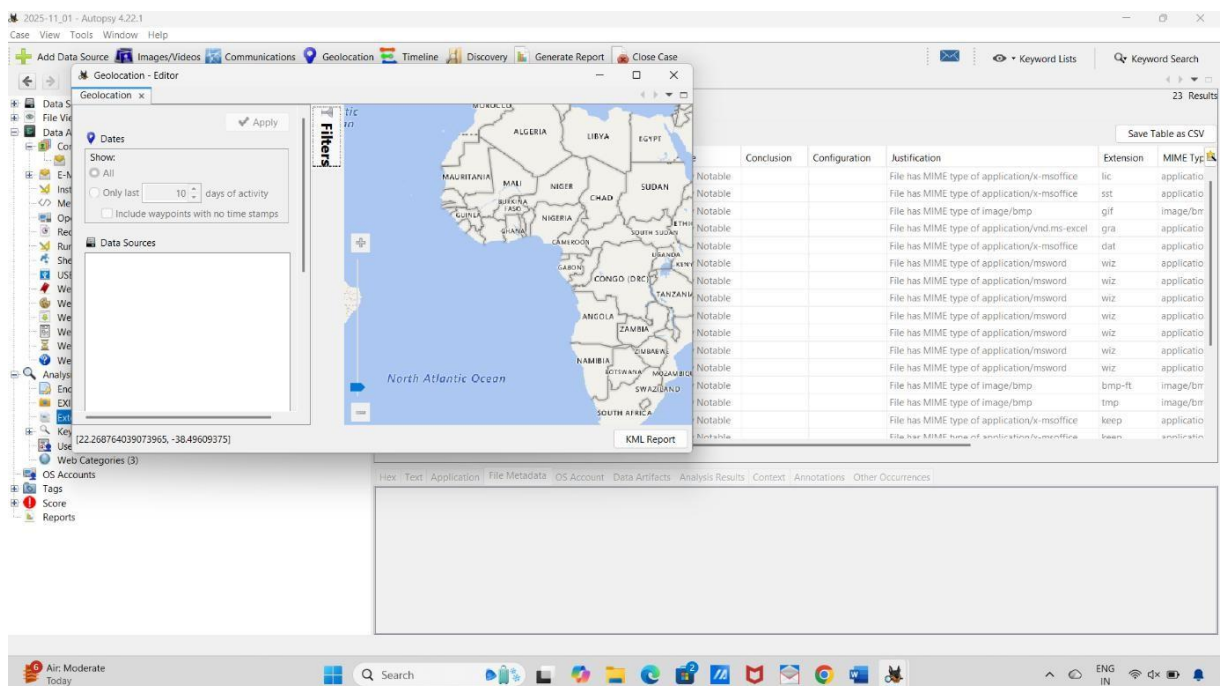
The direct way to look for the communication can be viewed here.



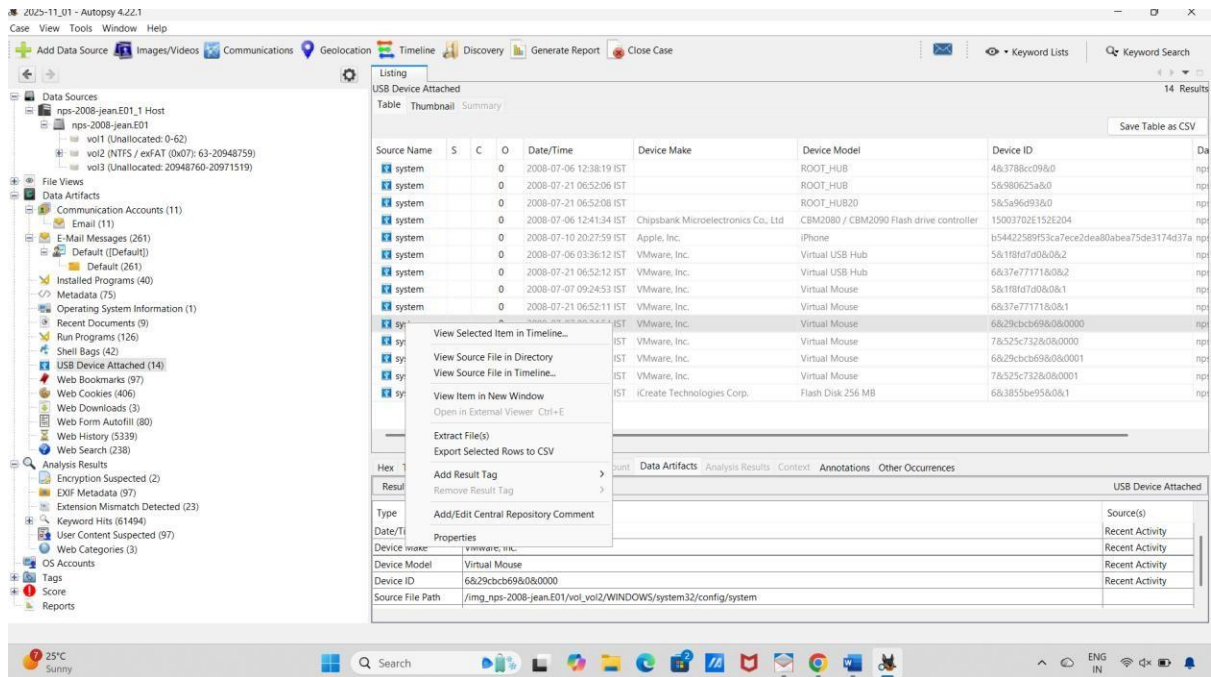
The Graphs can be made to understand the time line.



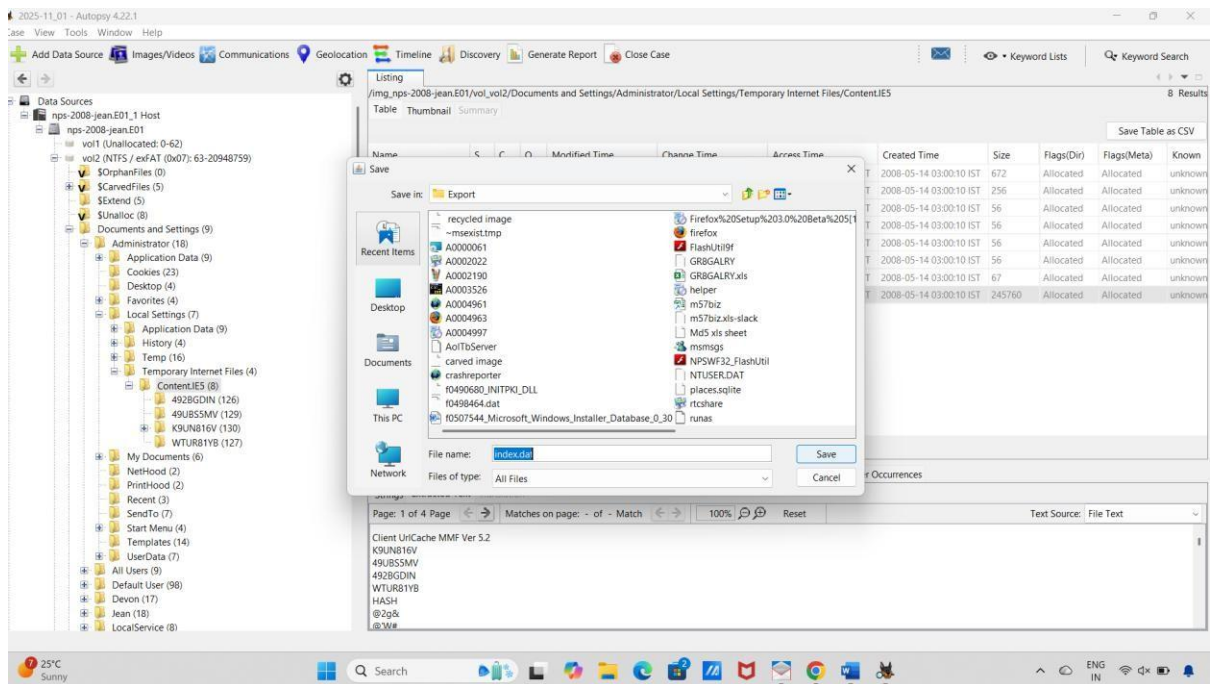
The Geo location can be viewed if necessary.



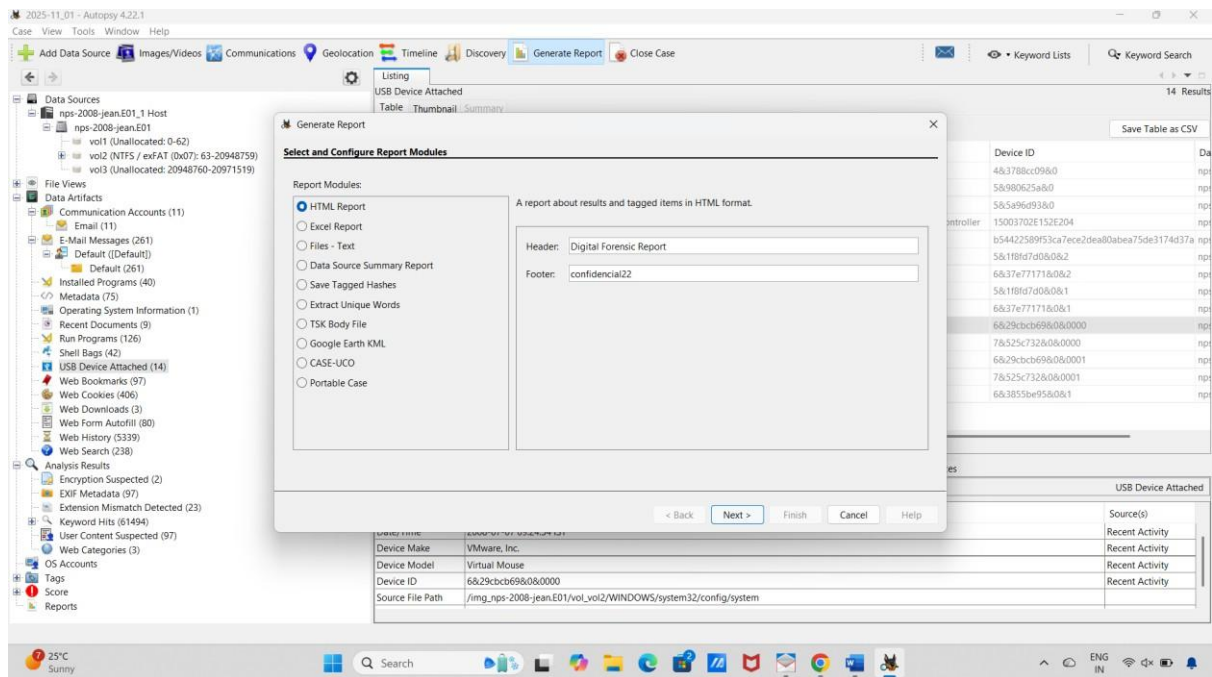
Right click on the file which need to be Extracted. Then click on the extract file option.



Save the extracted file in on folder for further analysis.



Click on Generate Report option then choose the format for Report.

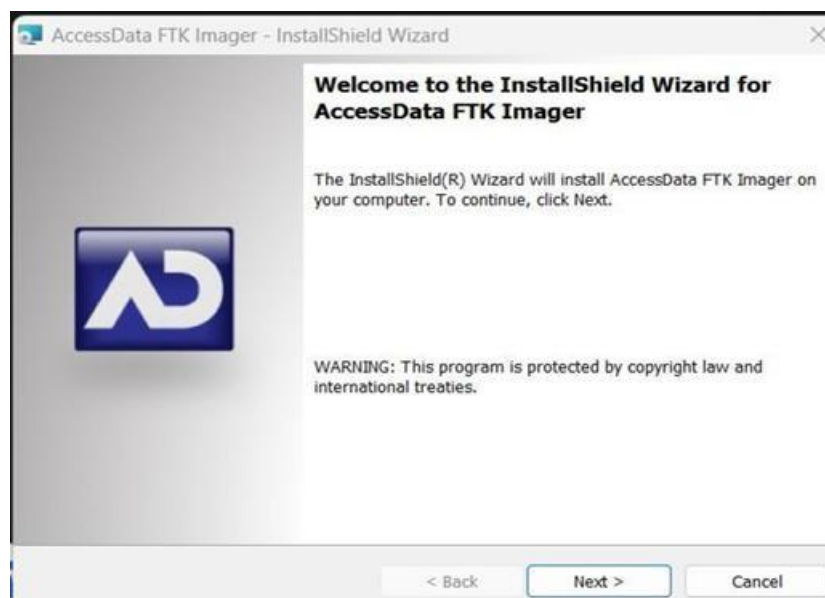


9. Create a forensic image (FTK Imager/dd), verify integrity (hashes), and recover deleted files via carving.

FTK Imager It is a forensic tool used to create the exact copies of digital storage devices such as USB, Hard drive and memory card without any altering. It is also used for file recovery (including deleted files), and viewing of file systems, ensuring data integrity through hashing for legal purposes. It's crucial for preserving evidence in corporate security, eDiscovery, and criminal investigations.

Installation on Windows

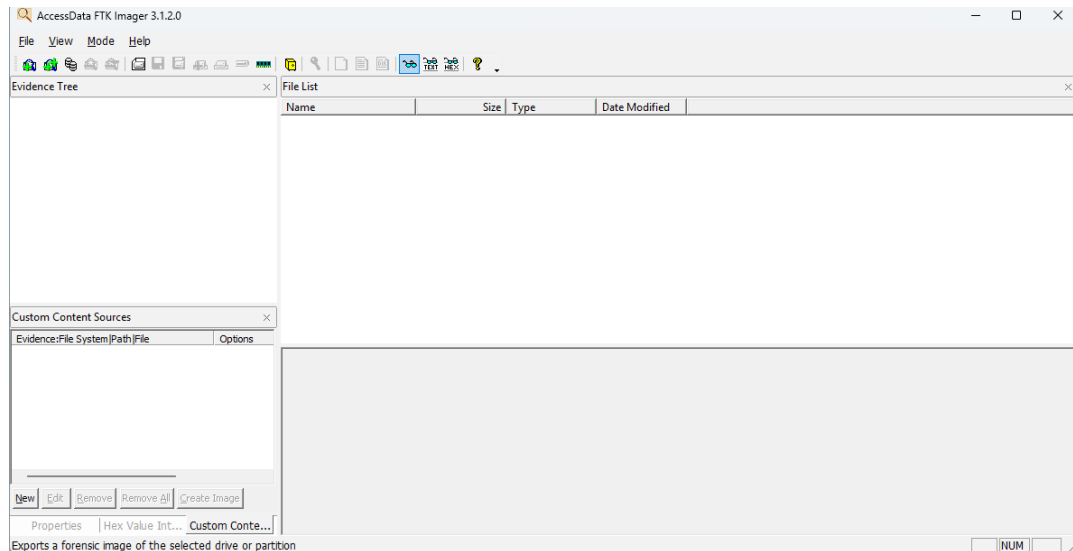
Step 1: Go to the website <https://accessdata-ftk-imager.software.informer.com/> and click Download. Now go to the file location and run the application.



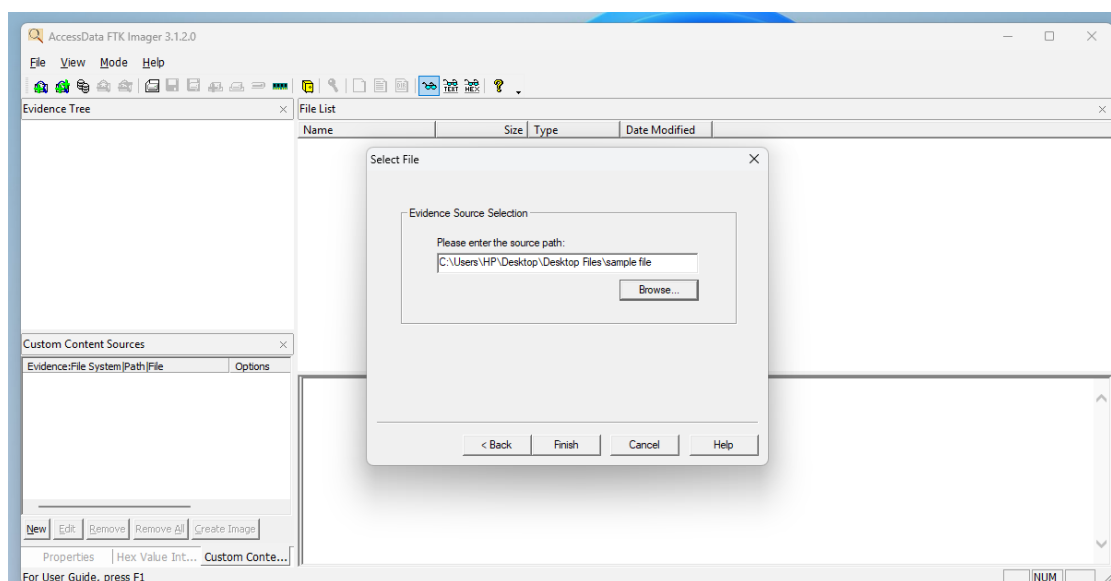
Step 2: Click on the next button.

Step 3: Click on install.

Step 4: Click on finish and Open the Access Data FTK Imager.



Step 5: In the menu navigation bar, you need to click on the File tab which will give you a drop down, like given in the image below, just click on the first one that says, Add Evidence Item.

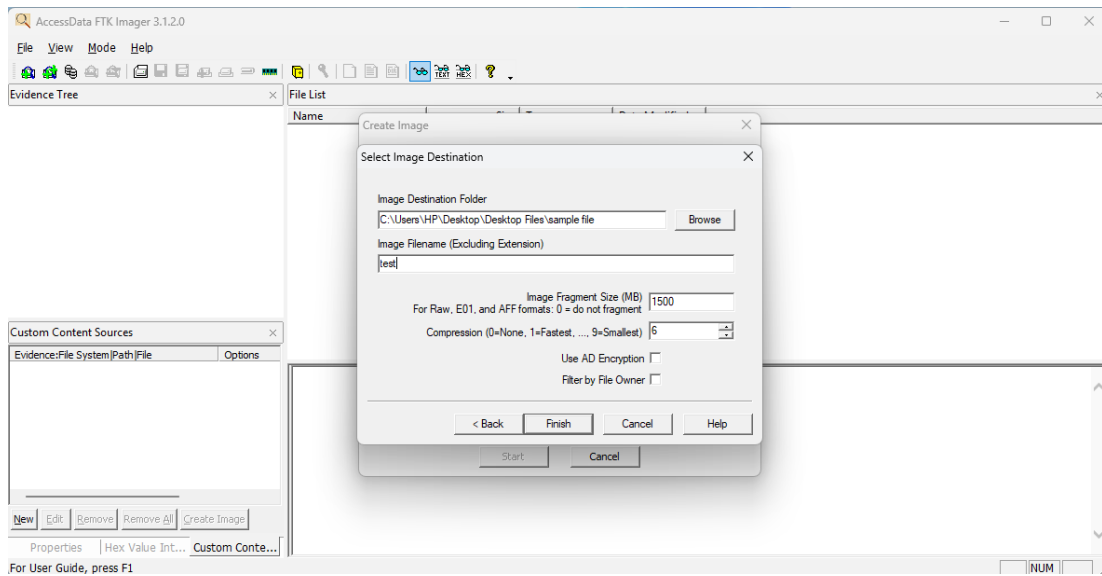


Step 6: Click the Add button for the Image Destination.

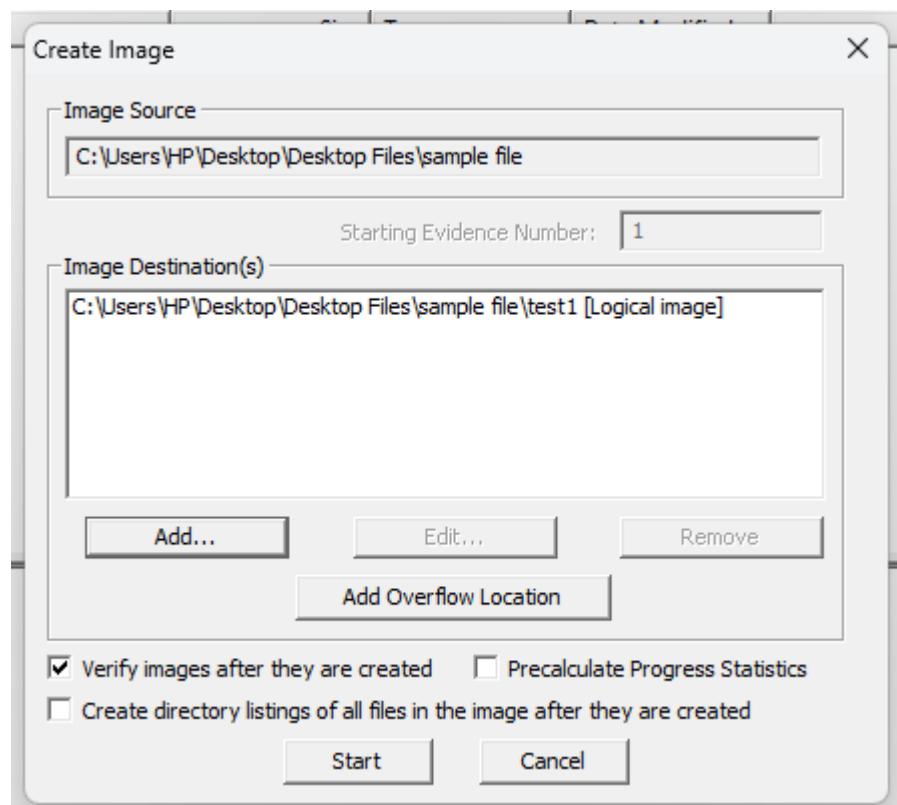
Select the Type of Forensic Image you would like to export.

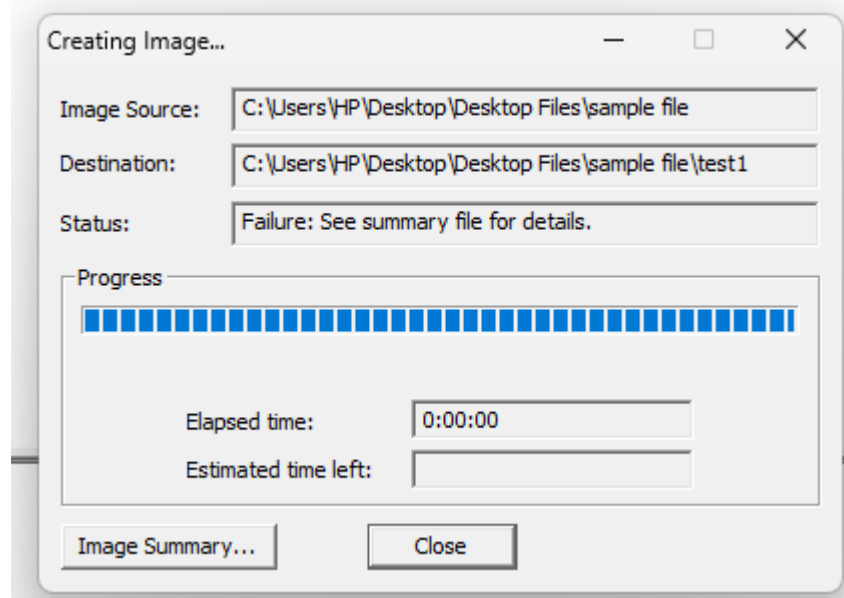
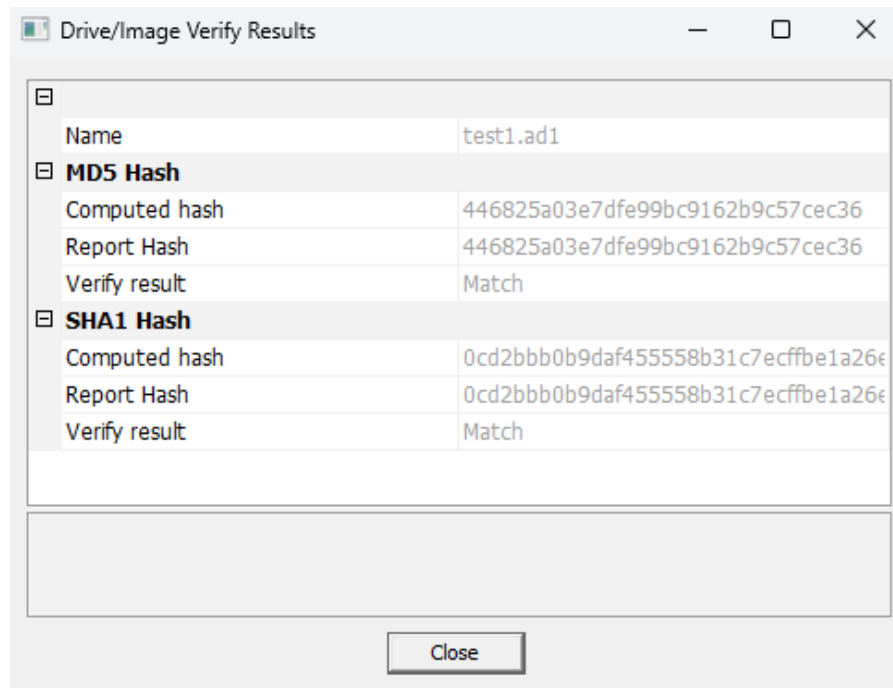
After that, you will have to enter information regarding the case now. You can either leave them blank or keep it general, this part is totally upon you.

Next, you will need to *Choose the Destination* that you would like to export the forensic image and *Name the Image*.



- Next, you will need to *Choose the Destination* that you would like to export the forensic image and *Name the Image*.





Lastly, you will need to wait for the Forensic Image to be created and then verified. The speed of creating the forensic image will vary based on your hardware. Once both have occurred, you have your forensic images ready.

10. Apply the IR lifecycle to a simulated incident (ransomware or data exfiltration), produce timeline, containment steps and incident report.

1. Basic

Information

Incident Title:

Incident ID / Case Number:

Date & Time Reported:

Date & Time Detected:

Reported By (Name/Department):

Incident Handler/Responder:

Severity Level: (Low / Medium / High / Critical)

2. Brief Description

A short summary of what happened, how it was detected, and which systems/users were affected.

3. Timeline of Event

Used	Time/Date	Event Description	Event Description	Source/Tool

4. Affected Assets

List all affected:

- Devices / Systems
- User accounts
- Applications
- Network segments
- Data types (PII, credentials, financial data)

5. Evidence Collected

- Logs (system, application, network logs)
 - Disk images / memory captures
 - Screenshots
 - Network captures (pcap files)
 - Artifacts (malware samples, suspicious files)
- (Include hash values and chain of custody if needed.)*

6. Actions Taken

- Containment:
- Eradication:

- c. Recovery
- 7. Impact Assessment
 - a. Data loss or corruption
 - b. Operational impact
 - c. Financial loss (if known)
 - d. Legal/regulatory implications
 - e. Reputation risk
- 8. Recommendations
 - a. Security improvements
 - b. Policy updates
 - c. Awareness training
 - d. Patch management suggestions
 - e. Additional monitoring tools
- 9. Conclusion
 - a. A concise summary confirming:
 - b. Whether the threat is fully removed
 - c. Current system status
 - d. Risk of recurrence
 - e. Overall lessons learn

Example:

A web server receives a huge number of fake requests from a single IP address. Because of the overload, the web server becomes slow and stops responding to real users. Legitimate customers cannot access the website until the attack traffic is blocked.

Type: Flooding attack

Method: Sending continuous HTTP requests

Impact: Website goes offline for 30 minutes

INCIDENT RESPONSE REPORT – DoS Attack

1. Incident Details

- Incident Title: DoS Attack on Company Web Server
- Incident ID: IR-2025-DOSEX01
- Date & Time Detected: 08 December 2025, 14:10 hrs
- Reported By: Network Monitoring System (NMS)
- Handled By: Cybersecurity Incident Response Team (CIRT)
- Severity: High

2. Brief Description of Incident

On 08 December 2025, the company's main web server experienced a sudden spike in incoming HTTP GET requests originating from a single suspicious IP address. The requests rapidly increased to several thousand per minute, overwhelming the server's processing capacity.

As a result, the website became slow, then unresponsive to legitimate users. This was identified as a Denial of Service (DoS) flooding attack

3. Timeline of Event

Time	Event
14:10	NMS alerts unusual HTTP traffic spike
14:12	Server response time increases drastically
14:15	Website becomes unavailable for real users
14:18	CIRT begins investigation
14:20	Traffic traced to a single IP (203.184.22.91)
14:22	Temporary firewall block placed on attacking IP
14:25	Traffic reduces, server stabilizes
14:35	Services fully restored
15:00	Post-incident analysis initiated

4. Affected Assets

- Web Server: Apache Web Server hosted on Linux
- Services Impacted:
 - Public website
 - Customer login portal
- Users Affected: All website visitors during the attack window
- Data Impact: No data breach detected; only service disruption

5. Evidence Collected

- Apache access logs
- Show repeated GET requests from IP 203.184.22.91
- Firewall logs
- System performance metrics (CPU spike to 98%)
- Screenshot of NMS showing traffic surge
- Network packet capture (pcap file) confirming repeated identical requests

6. Analysis & Findings (Root Cause)

- The attacker performed an HTTP GET Flood DoS attack by repeatedly hitting the website's root page.
- Attack came from a single external IP, not a botnet (so not DDoS).
- No signs of malware or internal compromise.
- The server became overloaded due to:
 - High request rate
 - Limited rate-limiting rules
 - No WAF (Web Application Firewall) in place
- Final Root Cause:
Server resources were exhausted due to high-volume fake traffic from one IP.

7. Actions Taken

Containment

- Blocked attacking IP using firewall (UFW/iptables)
- Disabled access to server temporarily for troubleshooting
- Enabled emergency rate limiting

Eradication

- Terminated long-waiting connections
- Cleared server cache
- Restarted Apache service to remove stalled processes

Recovery

- Restored normal traffic routes
- Verified service health and load capacity
- Website made live again by 14:35 hrs
- Monitored for additional 2 hours (no further anomalies)

8. Impact Assessment

- Service Downtime: 20 minutes
- Financial Loss: Minimal (short service outage)
- Customer Impact: Users unable to access website temporarily
- Data Integrity: No data loss or unauthorized access

- Reputation Impact: Low,

9. Recommendations

- Implement rate limiting on web server
- Set up Web Application Firewall (WAF)
- Use traffic filtering rules for repeated abnormal requests
- Enable Auto-Block for suspicious IPs
- Improve server capacity and load balancing
- Continuous monitoring using IDS/IPS
- Configure alert thresholds for unusual HTTP request spikes

10. Conclusion

The DoS attack was a single-IP flooding attack that caused temporary service unavailability. The incident was contained, eradicated, and resolved quickly with no data compromise.

Preventive measures are recommended to avoid recurrence and strengthen the organization's incident readiness.

